

**Bachelor Universitaire de Technologie**  
**Réseaux & Télécommunications**

Code ressource : **R4.Cyber.09**  
**sécurité dans les LAN**



**PARTIE I**

Coefficient : 10/300 (UE44 : 8 – UE45 : 2)  
Heures encadrées : 13 heures dont 6h de TP  
CM : 6h – TP : 6h – DS : 1h  
Deux notes : **TP1** + **TP2** (coef.1) + **DS** (coef.1)

2



**SÉANCE**  
**n°1**



**BUT R&T**

Ressource R4.Cyber.09

**Sommaire :**

**Introduction**

**PARTIE I : 3 heures de cours magistraux**

- 1. Attaque de table d'adresses Mac**  
Principe et conséquences du **Mac flooding** (inondation)  
Alternative par la sécurité des ports des commutateurs (**port security**)  
Alternative par le contrôle de tempêtes de trafic (**storm control**) **1h30**
- 2. Attaque par et dans un Vlan** **1h30**  
Principe et conséquences de **Switch spoofing** et **Vlan hopping**  
Alternative par la désactivation du protocole **DTP** et **configuration des ports**  
Alternative par une configuration pertinente du Vlan natif (**native Vlan**)  
Alternative par la configuration de Vlan privés (**private Vlan**)
- 3. Attaque par usurpation d'identité IP ou Mac**  
Conséquences du **DHCP spoofing** (usurpation) et **DHCP starvation** (famine)  
Alternative par la surveillance des requêtes DHCP (**DHCP snooping**)  
Alternative par l'inspection des adresses IP accédant aux ports (**IP source Guard**)  
Alternative par l'inspection des requêtes ARP (**Dynamic ARP inspection**)



## SÉANCE n°1



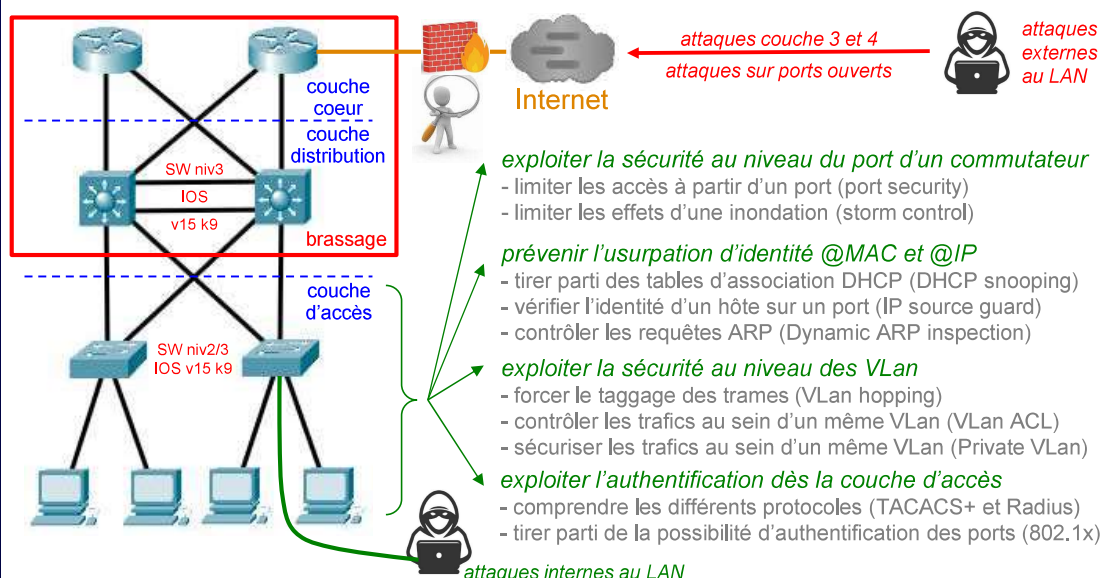
BUT R&T

Ressource R4.Cyber.09

## Introduction

### L'environnement :

L'attention se concentre sur les attaques à partir d'Internet  
Or la sécurisation du réseau LAN depuis l'intérieur est **vitale**  
**Virus** et **comportement des utilisateurs** sont des menaces  
Configurer les équipements pour limiter les vulnérabilités  
Mettre en place une sécurité pour prévenir les attaques  
Méthodologie de l'étude sur la couche « accès » :



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## Introduction

### Stratégie de défense :

La couche d'accès est souvent ignorée dans la sécurité  
Accent mis sur la protection externe et l'ouverture interne :

- placement de pare-feux entre le LAN et le monde extérieur
- contrôle des communications depuis l'extérieur (**deny any et on ouvre**)
- utilisation de matériels spécifiques (Stormshield-Fortinet-ASA-IPS/IDS)
- routeurs et commutateurs internes fournissent le trafic LAN nécessaire
- par défaut, **laisse passer tout le trafic pour faciliter la communication**
- la sécurité sur la couche d'accès est souvent minimale et négligée
- une attaque peut facilement être lancée sur la couche 2
- tout le réseau est alors compromis sans détection de la cause
- le niveau d'accès est devenu le plus sensible aux risques d'attaques

**Le réseau LAN est très vulnérable aux attaques internes**

Défense souvent placée au niveau du routeur (couche 3)

Attaques exploitant les fonctionnalités de couche 2

De nombreuses fonctionnalités de sécurité sont disponibles :

- connaître le fonctionnement des protocoles et l'utilisation de la couche 2
- connaître la manière d'exploiter le fonctionnement à des fins frauduleuses
- définir une stratégie de contre-mesures contre les attaques
- s'assurer du maintien du trafic usuel en limitant le ralentissement

Dans l'avenir, avec le déploiement des services réseaux **SDN** (NSX VMware ou ACI Cisco), la sécurité LAN sera prise en compte et les commutateurs ne seront pas ouverts par défaut et ne pourront pas transmettre sans autorisation explicite. Les contre-mesures étudiées restreindront les communications !





## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

# Introduction

## Base sécuritaire :

### Stratégie des mots de passe :

- respecter la stratégie : longueur, types de caractères, historique, ...
- « **enable password** » utilise un cryptage faible (utiliser « **enable secret** »)
- crypter tous les mots de passe même si facilement craquables (service)
- utiliser un **serveur d'authentification AAA** externe (pas de définition locale)

mettre tous les ports non utilisés doivent être désactivés  
forcer tous les ports non multiVLAN en mode « access »  
placer les ports non connectés dans un VLAN spécifique

### Bannière législative :

- informer les utilisateurs de la politique d'accès de l'entreprise
- avertir les non autorisés que leurs activités est répréhensible par la loi

### Accès au port console et au port réseau :

- éviter que les équipements soient facilement accessibles
- configurer une **authentification** sur le port console systématiquement
- limiter l'**accès à distance** aux seules hôtes administratifs par une ACL,
- imposer une connexion **cryptée** (https ou ssh)
- restreindre les **tentatives** et le temps de **session**

```
RT(conf)#ip http secure-server
RT(conf)#access-list 10 permit 192.168.10.1
RT(conf)#ip http access-class 10
RT(conf)#line vty 0 15
RT(conf-line)#transport input ssh
RT(conf-line)#access-class 10 in
RT(conf-line)#login local
```

### Gérer pertinemment les protocoles de confort de couche 2

- désactiver **SNMP** si pas besoin d'accès en écriture
- si besoin, utilisez uniquement **SNMPv3** offrant une authentification
- activer la **protection BPDU** de STP sur tous les ports du commutateur
- désactiver **CDP** qui envoie des informations en clair sans authentification
- désactiver **DTP** et mode « **auto** » qui négocie le passage en mode trunk.



## SÉANCE n°1



BUT R&T

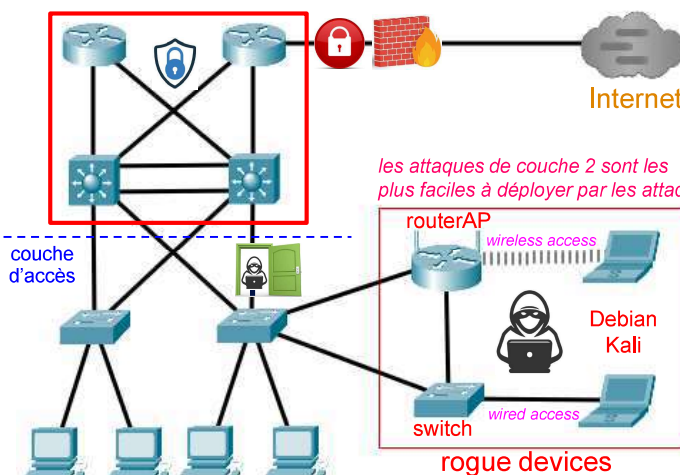
Ressource R4.Cyber.09

# Introduction

## Architecture d'étude :

### Les menaces peuvent revêtir différentes formes :

- un utilisateur désire obtenir le confort d'une liaison sans fil
- connexion d'un routeur personnel sans fil sur la couche d'accès
- mise en œuvre d'un réseau sans fil sans autorisation et sans sécurisation
- connexions filaire ou sans fil derrière le pare-feu de l'entreprise
- **failles : intercepter le trafic et pirater des sessions**



port d'accès ou contrôle d'un serveur de confiance, le réseau considère le trafic comme provenant d'un appareil connecté légitimement.

### Attaque par écoute

- sécurisez les transfert (SCP – SFTP)
- sécurisez la couche socket (SSL)
- sécurisez la couche transport (TLS)

### Types d'attaque

- Attaque de la couche MAC
  - inondation (MAC address flooding)
  - port security
  - MAC address VLAN access map
- Attaque VLAN
  - saut de VLAN (VLAN hopping)
  - attaque intraVLAN
  - désactivation DTP, forçage VLAN natif
  - Private VLAN
  - VLAN ACL / Port ACL
- Attaque par usurpation
  - famine DHCP (DHCP starvation)
  - usurpation DHCP (DHCP spoofing)
  - usurpation MAC (MAC spoofing)
  - usurpation ARP (ARP spoofing)
  - usurpation STP (STP compromise)
  - surveillance DHCP (DHCP snooping)
  - port security
  - dynamic ARP inspection (DAI)
  - enable Root Guard
- Attaque sur les commutateurs
  - CDP et DTP manipulation (disable)
  - SSH et Telnet attacks (v2 et ACL)
  - écoute du trafic en clair (HTTPS)



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-a/ Le principe du MAC flooding :

le commutateur conserve les @Mac durant un moment  
taille de la table d'adresses Mac limitée

inonder le commutateur de fausses @Mac sources  
la table d'@Mac du commutateur est saturée

300s  
par défaut  
SW2950

8 000 entrées pour une SW2950

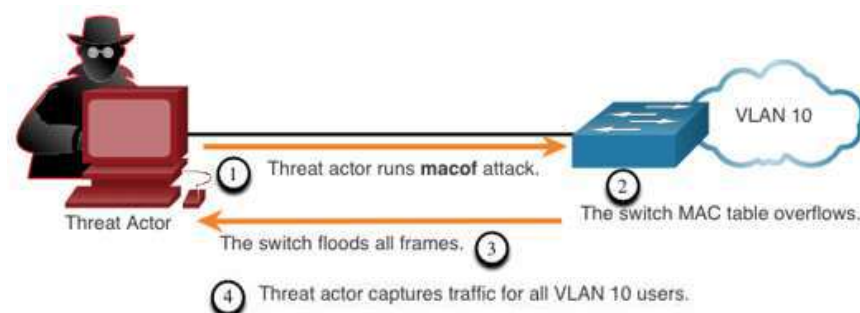
outils d'attaque  
+ de 100 000  
@Mac par minute

## 1-b/ La conséquence :

Plus de possibilité d'apprendre de nouvelles @Mac

le commutateur passe en mode diffusion (**fail-open mode**)

le commutateur agit tel un concentrateur : diffuse sur tous ports  
possibilité de capturer toutes les trames transmises



## SÉANCE n°1



BUT R&T

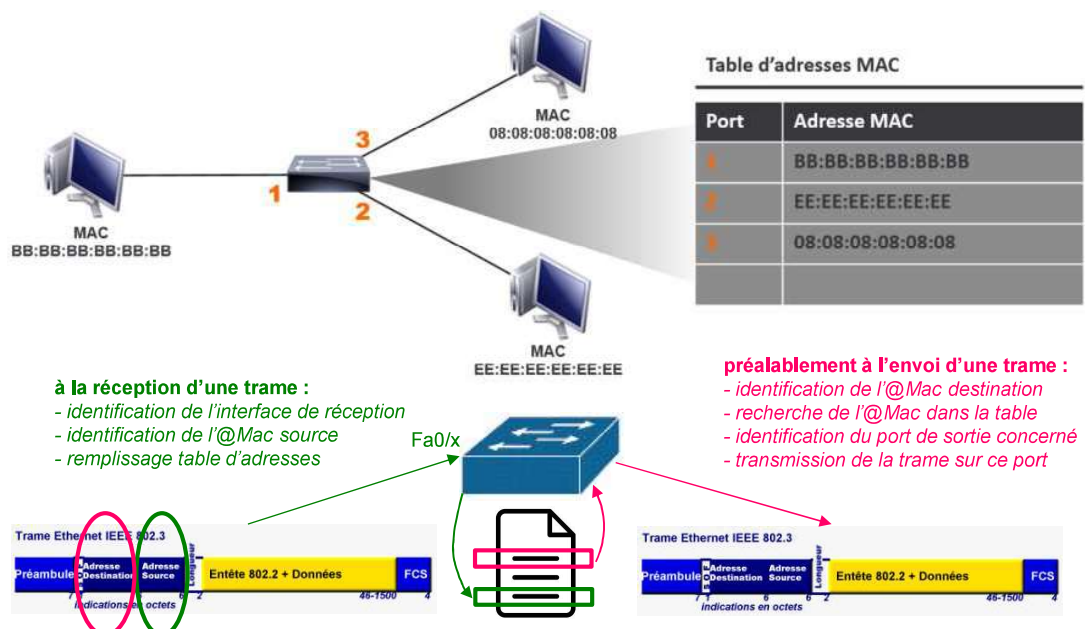
Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-c/ Exemple de Mac flooding : initialement

mise à jour de la table d'@Mac qui associe :

- adresses Ethernet sources
- aux ports physiques du commutateur
- permet d'envoyer les trames directement aux hôtes concernés
- évite la diffusion aveugle pratiqué par les concentrateurs







# SÉANCE n°1



BUT R&T

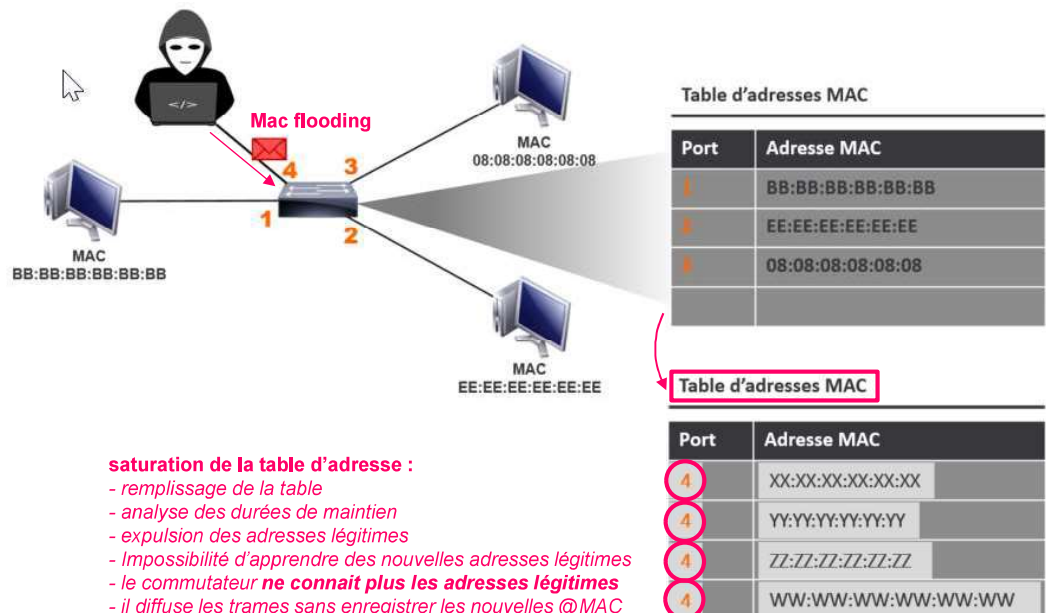
Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-c/ Exemple de Mac flooding : attaque

envoi en masse de trames avec @Mac sources fausses :

- chaque trame envoyé possède un @Mac source différente
- remplir l'espace mémoire limité de la table d'adresses
- nombre de trames suffisant avant expiration des anciennes
- effet de l'attaque peut varier selon marque/modèle switch



# SÉANCE n°1



BUT R&T

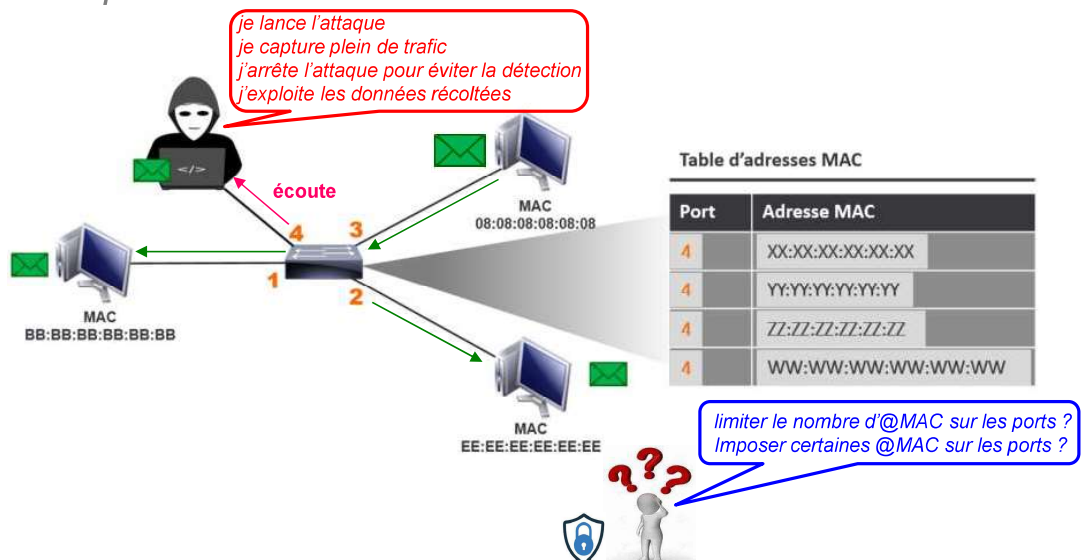
Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-c/ Exemple de Mac flooding : conséquence

écoute du trafic circulant par le commutateur :

- la table d'adresse est remplie de fausses adresses
- les adresses légitimes ne sont plus connues
- les trames sont diffusées sur tous les ports sauf l'émetteur
- les trames sont écoutées par l'attaquant
- inondation non détectée si elle reste ponctuelle
- exploitation d'autres vulnérabilités





## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-d/ Alternative sécurisation des ports (part1)

sécuriser systématiquement les ports du commutateur  
une sécurité adaptée à la fonction du port :

- désactiver tous les ports non utilisés (shutdown)

```
Switch#configure terminal
Switch(config)#interface range Fa0/11 - 15, Fa0/17, Fa0/19 - 21
Switch(config-if-range)#shutdown
%LINK-5-CHANGED: Interface FastEthernet0/11, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/12, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/13, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/14, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/15, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/17, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/19, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/20, changed state to administratively down
%LINK-5-CHANGED: Interface FastEthernet0/21, changed state to administratively down
Switch(config-if-range)#exit
Switch(config)#do show ip interface brief
```

- désactiver la configuration automatique des ports

```
Switch#configure terminal
Switch(config)#interface range Fa0/11 - 15, Fa0/17, Fa0/19 - 21
Switch(config-if-range)#switchport mode access
```

Par défaut, les ports peuvent être configurés en mode « auto dynamic » afin de passer en mode « trunk » si l'autre extrémité du lien est en trunk. Dans ce cas, la configuration de la sécurité du port est **rejetée** !

La sécurité d'un port ne peut être configurée que sur des ports configurés manuellement ou des ports configurés manuellement en mode « trunk ». A cet effet, il faut entrer la commande : (config-if)#**switchport mode access**

```
S1(config)# interface f0/1
S1(config-if)# switchport port-security
Command rejected: FastEthernet0/1 is a dynamic port.
S1(config-if)# switchport mode access
S1(config-if)# switchport port-security
S1(config-if)# end
```



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-d/ Alternative sécurisation des ports (part2)

une sécurité adaptée à la fonction du port :

- activer la sécurité sur tous les ports connectés à un hôte

```
Switch#configure terminal
Switch(config)#interface range Fa0/1 - 10, Fa0/18, Fa0/22 - 24
Switch(config-if-range)#switchport port-security
Switch(config-if-range)#end
Switch#show port-security interface Fa0/1
Port Security          : Enabled
Port Status            : Secure shutdown
Violation Mode         : Shutdown
Aging Time             : 0 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 1
Total MAC Addresses    : 0
Configured MAC Addresses : 0
Sticky MAC Addresses   : 0
Last Source Address:Vlan : 0000.0000.0000:0
Security Violation Count : 0
```

La sécurité du port FA0/1 est activée

Port non connecté à un équipement

Mode de violation arrêté

Nombre maximum d'adresses Mac

Aucun hôte connecté au port

```
Switch#show port-security interface Fa0/1
Port Security          : Enabled
Port Status            : Secure up
Violation Mode         : Shutdown
Aging Time             : 0 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 1
Total MAC Addresses    : 1
Configured MAC Addresses : 0
Sticky MAC Addresses   : 0
Last Source Address:Vlan : 0060.1234.5678:1
Security Violation Count : 0
```

Si un hôte est connecté au port, le commutateur ajoute automatiquement l'adresse Mac de cet hôte en tant que MAC sécurisée à la première trame reçue !

Si une autre @Mac arrive sur le même port, alors ce dernier passe dans l'état désactivé par erreur !

```
Switch#show port-security interface Fa0/1
Port Security          : Enabled
Port Status            : Secure shutdown
Maximum MAC Addresses  : 1
Total MAC Addresses    : 0
Last Source Address:Vlan : 00A0.1234.5678:1
Security Violation Count : 1 @Mac responsable
```





## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-d/ Alternative sécurisation des ports (part3)

une sécurité adaptée à la fonction du port :

- activer d'autres spécificités de sécurité selon les besoins

Nombre maximum d'@Mac autorisées sur un port  
valeur par défaut de 1  
nombre maximum dépendant du commutateur et de l'IOS  
(conf-if)#switchport port-security maximum <1-8192>

```
Switch#show port-security interface Fa0/1
Port Security          : Enabled
Port Status            : Secure-up
Maximum MAC Addresses  : 3
Total MAC Addresses    : 3
Last Source Address:Vlan : 00D0.1234.5678:1
Security Violation Count : 0
```

3 @Mac autorisées  
Secure-shutdown  
3  
0  
00E0.1234.5678:1  
1

conséquence  
de 4 @Mac

3ème @Mac reçue

```
S1(config-if)# switchport port-security ?
aging      Port-security aging commands
mac-address Secure mac address
maximum    Max secure addresses
violation  Security violation mode
<cr>
```

```
Maximum MAC Addresses : 3
Total MAC Addresses   : 1
Configured MAC Addresses : 1
```

Définition d'@Mac autorisées sur un port  
Selon trois manières :

1/Statique : configuration d'@Mac de manière manuelle  
(conf-if)#switchport port-security mac-address H.H.H

```
interface FastEthernet0/1
switchport port-security mac-address sticky
switchport port-security mac-address sticky 00C0.1234.5678
switchport port-security mac-address sticky 00D0.1234.5678
```

2/Dynamique sans sauvegarde : l'@Mac connecté est automatiquement sécurisé  
@Mac source non ajoutée à la « configuration en cours », d'où perte si redémarrage  
(conf-if)#switchport port-security

3/Dynamique avec sauvegarde : l'@Mac connectée est automatiquement sécurisé  
@Mac source ajoutée à la « configuration en cours » et peut être sauvegardée  
(conf-if)#switchport port-security mac-address sticky



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-d/ Alternative sécurisation des ports (part4)

L'obsolescence de la sécurité des ports : « aging »

- définir un temps de maintien des @Mac sécurisées par port
- concerne aussi bien des @Mac définie en statique / dynamique
- la suppression est basée sur le temps ou l'inactivité
- n'impacte pas les @Mac renseignées manuellement (sticky)

L'obsolescence statique de la sécurité sur un port :

- (conf-if)#switchport port-security aging time « temps »
- time : suivi du temps en minutes (de 1 minute à une journée)
- (conf-if)#switchport port-security aging type [absolute|inactivity]
- absolute : @Mac sécurisées supprimées après le temps défini
- inactivity : @Mac sécurisées supprimées après l'inactivité définie
- retire les @Mac de la table d'adresses sécurisées
- maintien les @Mac dans la table d'adresses classique ...

```
Switch#sh port-security int fa0/1
Port Security          : Enabled
Port Status            : Secure-up
Violation Mode         : Restrict
Aging Time             : 1 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 5
Total MAC Addresses    : 3
Configured MAC Addresses : 1
Sticky MAC Addresses   : 0
Last Source Address:Vlan : 00C0.1234.
Security Violation Count : 0
```

maintien dans la table  
sécurisée durant 1 min #show port-security address

| Vlan                                                   | Mac Address    | Type              | Ports           | Remaining Age(mins) |
|--------------------------------------------------------|----------------|-------------------|-----------------|---------------------|
| 1                                                      | 00B0.1234.5678 | SecureConfigured  | FastEthernet0/1 | -                   |
| 1                                                      | 00C0.1234.5678 | DynamicConfigured | FastEthernet0/1 | -                   |
| 1                                                      | 00D0.1234.5678 | DynamicConfigured | FastEthernet0/1 | -                   |
| Total Addresses in System (excluding one mac per port) |                |                   |                 | 2                   |

| Vlan                                                   | Mac Address    | Type             | Ports           | Remaining Age(mins) |
|--------------------------------------------------------|----------------|------------------|-----------------|---------------------|
| 1                                                      | 00B0.1234.5678 | SecureConfigured | FastEthernet0/1 | -                   |
| Total Addresses in System (excluding one mac per port) |                |                  |                 | 0                   |

restent comptabilisées.



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-d/ Alternative sécurisation des ports (part5)

Réaction du port si @Mac reçue ≠ table @Mac sécurisées :

- violation de port constatée
- port entre dans l'état désactivé par erreur « *Secure-down* »
- possibilité de définir les modes de violation du port
- (conf-if)#switchport port-security violation [*shutdown*]*restrict**protect*]

#### Shutdown (par défaut) :

le port immédiatement à l'état « désactivé par erreur »  
la del du port s'éteint (shutdown)  
envoi d'un message syslog  
incrémente le compteur de violation  
la table d'adresse Mac classique se vide des @ concernant l'interface  
doit être réactivé manuellement (shutdown et no shutdown)

#### Restrict (restreindre) :

plus aucune @Mac n'est ajoutée à la table d'adresses classique  
le port supprime les paquets dont l'adresse source est inconnue  
envoi un message syslog  
incrémente le compteur de violation  
restriction levée si suppression suffisante d'@Mac sécurisées  
restriction levée si augmentation nombre maximal d'@Mac sécurisées

#### Protect (protéger) : mode le moins sécurisé

plus aucune @Mac n'est ajoutée à la table d'adresses classique  
le port supprime les paquets dont l'adresse source est inconnue  
pas d'envoi de message syslog  
incrémente le compteur de violation  
restriction levée si suppression suffisante d'@Mac sécurisées  
restriction levée si augmentation nombre maximal d'@Mac sécurisées



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-e/ Analyse de la sécurité (part1)

Importance de savoir « décoder » la configuration d'un port

- #show port-security interface Fa0/x
- #show port-security address

Configuration  
de la sécurité  
du port Fa0/1

```
Switch(conf)#interface FastEthernet0/1
Switch(conf-if)#switchport mode access
Switch(conf-if)#switchport port-security
Switch(conf-if)#switchport port-security maximum 3
Switch(conf-if)#switchport port-security mac-address 00B0.1234.5678
Switch(conf-if)#switchport port-security mac-address sticky
```

sécurisation du port à une seule @Mac

extension d'autorisation à 3 @Mac

@Mac statique définie manuellement

apprentissage @Mac dynamique autorisée à concurrence de ?

**Analyse** : spécification d'un maximum 3@Mac sur le port Fa0/1 dont une configurée manuellement puis port configuré afin d'apprendre dynamiquement des @Mac jusqu'à 3 - 1 au maximum. Dans notre cas, nous avons atteint le maximum d'@Mac sécurisées dont 2 apprises dynamiquement.

Si une autre @Mac se présente sur le port, le port passera en mode « shutdown » demander une intervention manuelle afin de le réactiver en mode transmission.

faire un shutdown puis  
no shutdown sur le port

Security Violation Count : 1

Switch#sh port-security address

Secure Mac Address Table

| Vlan | Mac Address    | Type             | Ports           | Remaining Age(mins) |
|------|----------------|------------------|-----------------|---------------------|
| 1    | 00B0.1234.5678 | SecureConfigured | FastEthernet0/1 | -                   |
| 1    | 00D0.1234.5678 | SecureSticky     | FastEthernet0/1 | -                   |
| 1    | 00E0.1234.5678 | SecureSticky     | FastEthernet0/1 | -                   |

Total Addresses in System (excluding one mac per port) : 2  
Max Addresses limit in System (excluding one mac per port) : 8192

Switch#show port-security interface fa0/1

```
Port Security : Enabled
Port Status : Secure-up
Violation Mode : Shutdown
Aging Time : 0 mins
Aging Type : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses : 3
Total MAC Addresses : 3
Configured MAC Addresses : 1
Sticky MAC Addresses : 2
Last Source Address:Vlan : 00E0.1234.5678:1
Security Violation Count : 0
```

Switch#sh mac-address-table

Mac Address Table

| Vlan | Mac Address    | Type    | Ports |
|------|----------------|---------|-------|
| 1    | 0000.0c81.92e6 | DYNAMIC | Fa0/2 |
| 1    | 00b0.1234.5678 | STATIC  | Fa0/1 |
| 1    | 00d0.1234.5678 | STATIC  | Fa0/1 |
| 1    | 00e0.1234.5678 | STATIC  | Fa0/1 |





## SÉANCE n°1



**BUT R&T**  
Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-e/ Analyse de la sécurité (part2)

Importance de savoir « décoder » la désactivation d'un port  
- messages lorsqu'un port passe à l'état désactivé par erreur

```
*Sep 20 06:44:54.966: %PM-4-ERR_DISABLE: psecure-violation error detected on Fa0/18, putting Fa0/18 in
err-disable state
*Sep 20 06:44:54.966: %PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused by MAC
address 000c.292b.4c75 on port FastEthernet0/18.
*Sep 20 06:44:55.973: %LINEPROTO-5-PPDOWN: Line protocol on Interface FastEthernet0/18, changed state
to down
*Sep 20 06:44:56.971: %LINK-3-UPDOWN: Interface FastEthernet0/18, changed state to down
```

- #show port-security interface Fa0/18

**Analyse :** l'état du port Fa0/18 est en mode **désactivé par erreur** conduisant à l'état **Secure-shutdown** du port du à une violation dont le **compteur s'incrémente de 1**. L'administrateur connaît la **dernière @Mac** ayant engendré la violation conduisant à l'état de blocage.

Nous avons ici **3 @Mac autorisées** sur le port Fa0/18 dont une définie manuellement, **deux autres apprises** de manière dynamique sans limitation de temps. La présence d'une 4<sup>ème</sup> @Mac a donc conduit à un dépassement de la capacité et l'application de l'action définie : **shutdown** du port.

| Vlan | Mac Address    | Type              | Ports           | Remaining Age(mins) |
|------|----------------|-------------------|-----------------|---------------------|
| 1    | 00B0.1234.5678 | SecureConfigured  | FastEthernet0/1 | -                   |
| 1    | 00C0.1234.5678 | DynamicConfigured | FastEthernet0/1 | -                   |
| 1    | 00D0.1234.5678 | DynamicConfigured | FastEthernet0/1 | -                   |

Total Addresses in System (excluding one mac per port) : 2  
Max Addresses limit in System (excluding one mac per port) : 8192

Il faut réactiver la port manuellement par le commande (conf-if)#shutdown suivie d'une (conf-if)no shutdown

```
Switch#show interface fa0/18
FastEthernet0/18 is down, line protocole is down
(err-disabled) (output omitted)
```

```
Switch#show port-security interface fa0/18
Port Security : Enabled
Port Status : Secure-shutdown
Violation Mode : Shutdown
Aging Time : 0 mins
Aging Type : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses : 3
Total MAC Addresses : 3
Configured MAC Addresses : 1
Sticky MAC Addresses : 2
Last Source Address:Vlan : 00E0.1234.5678:1
Security Violation Count : 1
```



## SÉANCE n°1



**BUT R&T**  
Ressource R4.Cyber.09

# 1- Attaque de table d'adresses MAC

## 1-e/ Analyse de la sécurité (part3a)

Détection de la cause d'erreurs sur un port : « err-disabled »

- violation de la sécurité d'un port (@MAC invalide ou supérieure au max)
- violation de la protection d'un port en PortFast avec BPDU Guard
- mauvaise configuration des ports d'extrémité d'un Etherchannel
- incompatibilité des modes duplex sur les extrémités d'un lien
- liaison unidirectionnelle détectée par UniDirectional Link Detection
- n° révision BPDU reçu par un port du Root en STP > n° référence
- instabilité d'un lien up/down (link flapping)
- détection tardive de collisions
- dépassement de limite de débit de surveillance DHCP
- problème d'inspection ARP ...

SW(conf)#errdisable detect [all | cause-name ]

```
SWL2(config)#errdisable detect cause ?
all Enable error detection on all cases
arp-inspection Enable error detection for arp inspection
dhcp-rate-limit Enable error detection on dhcp-rate-limit
dtp-flap Enable error detection on dtp-flapping
gbic-invalid Enable error detection on gbic-invalid
inline-power Enable error detection for inline-power
l2ptguard Enable error detection on l2protocol-tunnel
link-flap Enable error detection on linkstate-flapping
loopback Enable error detection on loopback
pagp-flap Enable error detection on pagp-flapping
pppoe-ia-rate-limit Enable error detection on PPPoE IA rate-limit
psp Enable error detection on PSp
security-violation Enable error detection on 802.1x-guard
stp-config-mismatch Enable error detection on SFP config mismatch
```



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-e/ Analyse de la sécurité (part3b)

Réactivation d'un port : « err-disabled »

- cause de l'état « err-disabled » doit être supprimée
- désactiver puis réactiver le port : shutdown / no shutdown
- possibilité de réactivation automatique après un temps spécifié
- temps d'attente au minimum de 30s et par défaut de 300s
- **fonction de réactivation automatique activée par défaut**

SW(conf)#errdisable recovery cause psecure-violation (active la cause)

SW(conf)#errdisable recovery interval 60 (concerne toutes les causes)

SW#show errdisable recovery (affiche l'état des réactivation automatiques)

| SWL2(config)#errdisable recovery cause ? |                                                            |              | SWL2#sh errdisable recovery |          |  |
|------------------------------------------|------------------------------------------------------------|--------------|-----------------------------|----------|--|
|                                          | ErrDisable Reason                                          | Timer Status |                             |          |  |
| all                                      | Enable timer to recover from all error causes              |              | arp-inspection              | Disabled |  |
| arp-inspection                           | Enable timer to recover from arp inspection error          |              | bpduguard                   | Disabled |  |
|                                          | disable state                                              |              | channel-misconfig (STP)     | Disabled |  |
| bpduguard                                | Enable timer to recover from BPDU Guard error              |              | dhcp-rate-limit             | Disabled |  |
| channel-misconfig                        | Enable timer to recover from channel misconfig error (STP) |              | dtp-flap                    | Disabled |  |
| dhcp-rate-limit                          | Enable timer to recover from dhcp-rate-limit error         |              | gbic-invalid                | Disabled |  |
| dtp-flap                                 | Enable timer to recover from dtp-flap error                |              | inline-power                | Disabled |  |
| gbic-invalid                             | Enable timer to recover from invalid GBIC error            |              | l2ptguard                   | Disabled |  |
| inline-power                             | Enable timer to recover from inline-power error            |              | link-flap                   | Disabled |  |
| l2ptguard                                | Enable timer to recover from l2protocol-tunnel error       |              | mac-limit                   | Disabled |  |
| link-flap                                | Enable timer to recover from link-flap error               |              | link-monitor-failure        | Disabled |  |
| link-monitor-failure                     | Enable timer to recover from link monitoring failure       |              | loopback                    | Disabled |  |
| loopback                                 | Enable timer to recover from loopback error                |              | oam-remote-failure          | Disabled |  |
| mac-limit                                | Enable timer to recover from mac limit disable state       |              | port-mode-failure           | Disabled |  |
| oam-remote-failure                       | Enable timer to recover from OAM detected remote failure   |              | pppoe-ia-rate-limit         | Disabled |  |
|                                          |                                                            |              | <b>psecure-violation</b>    | Enabled  |  |
| pagp-flap                                | Enable timer to recover from pagp-flap error               |              | security-violation          | Disabled |  |
| port-mode-failure                        | Enable timer to recover from port mode change failure      |              | sfp-config-mismatch         | Disabled |  |
| pppoe-ia-rate-limit                      | Enable timer to recover from PPPoE IA rate-limit error     |              | storm-control               | Disabled |  |
| <b>psecure-violation</b>                 | Enable timer to recover from psecure violation error       |              | udld                        | Disabled |  |
| psp                                      | Enable timer to recover from psp                           |              | unicast-flood               | Disabled |  |
| security-violation                       | Enable timer to recover from 802.1x violation error        |              | vmps                        | Disabled |  |
| sfp-config-mismatch                      | Enable timer to recover from SFP config mismatch error     |              |                             |          |  |
| storm-control                            | Enable timer to recover from storm-control error           |              |                             |          |  |
| udld                                     | Enable timer to recover from udld error                    |              |                             |          |  |
| unicast-flood                            | Enable timer to recover from unicast flood error           |              |                             |          |  |
| vmps                                     | Enable timer to recover from vmps shutdown error           |              |                             |          |  |

Timer interval: 60 seconds



# SÉANCE n°1



BUT R&T

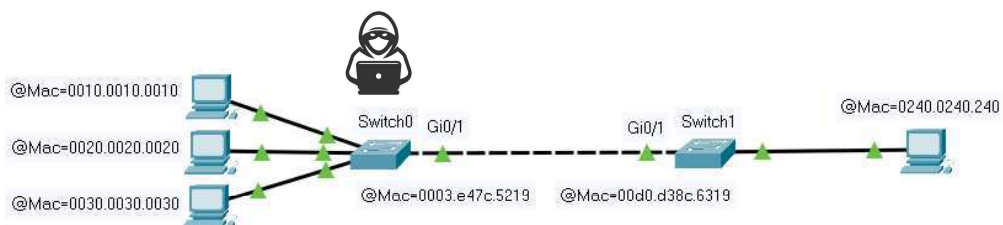
Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-f/ Exercice de sécurisation (part1)

Rappel des commandes #show

- **#show port-security** affiche les paramètres de sécurité des ports
- **#show port-security interface Fa0/x** affiche le détail d'une interface
- **#show run | begin interface Fa0/x** affiche configuration de l'interface
- **#show port-security address** affiche les @Mac sécurisées man/dyn



| MAC Table for Switch0 |                |                    |
|-----------------------|----------------|--------------------|
| VLAN                  | Mac Address    | Port               |
| 1                     | 0010.0010.0010 | FastEthernet0/1    |
| 1                     | 0020.0020.0020 | FastEthernet0/2    |
| 1                     | 0030.0030.0030 | FastEthernet0/3    |
| 1                     | 00D0.D38C.6319 | GigabitEthernet0/1 |
| 1                     | 0240.0240.0240 | GigabitEthernet0/1 |

| MAC Table for Switch1 |                |                    |
|-----------------------|----------------|--------------------|
| VLAN                  | Mac Address    | Port               |
| 1                     | 0003.E47C.5219 | GigabitEthernet0/1 |
| 1                     | 0010.0010.0010 | GigabitEthernet0/1 |
| 1                     | 0020.0020.0020 | GigabitEthernet0/1 |
| 1                     | 0030.0030.0030 | GigabitEthernet0/1 |
| 1                     | 0240.0240.0240 | FastEthernet0/24   |

aucune sécurité appliquée sur les ports du Switch0  
possibilité de se connecter sur l'un des ports  
Possibilité d'effectuer du Mac Flooding

Port Gi0/1 recevant le trafic sans aucune limitation,  
possibilité de subir du Mac Flooding





# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

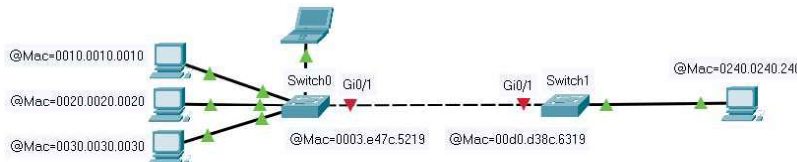
### 1-f/ Exercice de sécurisation (part2)

Mise en œuvre de palliatifs sur le Switch1:

- activer sécurité du port Gi0/1

limitation à 1@Max par défaut prise par l'@MAC dynamique Gi0/1 SW0  
mode de violation configurée à « Shutdown » par défaut

port Gi0/1 désactivé par erreur si trafic d'autres @Mac du SW0  
table d'adresses Mac classique vidée d'@Mac venant du port Gi0/1  
aucun trafic permis depuis le SW0 vers le SW1 ...



@Mac causant la violation

violation

désactivation par erreur

| VLAN | Mac Address    | Port            |
|------|----------------|-----------------|
| 1    | 0010.0010.0010 | FastEthernet0/1 |

```
Switch#sh port int gi0/1
Port Security          : Enabled
Port Status            : Secure-up
Violation Mode         : Shutdown
Aging Time             : 0 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 1
Total MAC Addresses    : 1
Configured MAC Addresses : 0
Sticky MAC Addresses   : 0
Last Source Address:Vlan : 0003.E47C.5219:1
Security Violation Count : 0
```

| VLAN | Mac Address    | Port             |
|------|----------------|------------------|
| 1    | 0240.0240.0240 | FastEthernet0/24 |

```
Switch#sh port-security int gi0/1
Port Security          : Enabled
Port Status            : Secure-shutdown
Violation Mode         : Shutdown
Aging Time             : 0 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 1
Total MAC Addresses    : 0
Configured MAC Addresses : 0
Sticky MAC Addresses   : 0
Last Source Address:Vlan : 0010.0010.0010:1
Security Violation Count : 1
```

perte des @Mac



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-f/ Exercice de sécurisation (part3)

Mise en œuvre de palliatifs sur le Switch1:

- étendre le nombre d'@Mac autorisé sur le port à 26

limitation à 26@Max transmise par l'@MAC dynamique Gi0/1 SW0  
observer les @Mac renseignées dans la table d'@Mac sécurisées  
ces @Mac ne sont pas ajoutées à la configuration

définir ces @Mac manuellement ou dynamiquement avec sauvegarde  
sticky fonctionne si non référencées dynamiquement sans sauvegarde

```
interface GigabitEthernet0/1
switchport mode access
switchport port-security
switchport port-security maximum 26
switchport port-security mac-address sticky
```

```
Switch#sh port-security add
Secure Mac Address Table
```

| Vlan | Mac Address    | Type              | Ports              | Remaining Age (mins) |
|------|----------------|-------------------|--------------------|----------------------|
| 1    | 0003.E47C.5219 | DynamicConfigured | GigabitEthernet0/1 |                      |
| 1    | 0010.0010.0010 | DynamicConfigured | GigabitEthernet0/1 |                      |
| 1    | 0020.0020.0020 | DynamicConfigured | GigabitEthernet0/1 |                      |
| 1    | 0030.0030.0030 | DynamicConfigured | GigabitEthernet0/1 |                      |

```
Switch#sh port-security int gi0/1
Port Security          : Enabled
Port Status            : Secure-up
Violation Mode         : Shutdown
Aging Time             : 0 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 26
Total MAC Addresses    : 4
Configured MAC Addresses : 0
Sticky MAC Addresses   : 4
Last Source Address:Vlan : 0003.E47C.5219:1
Security Violation Count : 0
```

```
interface GigabitEthernet0/1
switchport mode access
switchport port-security
switchport port-security maximum 26
switchport port-security mac-address sticky
```

| Vlan | Mac Address    | Type         |
|------|----------------|--------------|
| 1    | 0003.E47C.5219 | SecureSticky |
| 1    | 0010.0010.0010 | SecureSticky |
| 1    | 0020.0020.0020 | SecureSticky |
| 1    | 0030.0030.0030 | SecureSticky |

reload du switch  
désactivation/activation sécurisé sur le port

indique l'@Mac Gi0/1 SW0



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 1- Attaque de table d'adresses MAC

### 1-f/ Exercice de sécurisation (part4)

Mise en œuvre de palliatifs sur le Switch1:

- *ajuster la configuration au contexte local*

*limiter les @Max à celles transmises par le port Gi0/1 SW0*

*passer en mode de violation « restrictif » pour éviter les shutdown*

*les @Mac provenant du port Gi0/1 du SW0 sont figés*

*toutes autres @Mac provenant de ce port sera ignorée ainsi que le trafic*

```
interface GigabitEthernet0/1
 switchport mode access
 switchport port-security
 switchport port-security maximum 4
 switchport port-security mac-address sticky
 switchport port-security violation restrict
 switchport port-security mac-address sticky 0003.E47C.5219
 switchport port-security mac-address sticky 0010.0010.0010
 switchport port-security mac-address sticky 0020.0020.0020
 switchport port-security mac-address sticky 0030.0030.0030
```

4 adresses référencées  
dans la table d'adresses sécurisée  
et dans la configuration du switch

```
Switch#sh port-security int gi0/1
Port Security : Enabled
Port Status : Secure-up
Violation Mode : Restrict
Aging Time : 0 mins
Aging Type : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses : 4
Total MAC Addresses : 4
Configured MAC Addresses : 0
Sticky MAC Addresses : 4
Last Source Address:Vlan : 0003.E47C.5219:1
Security Violation Count : 0
```



**Pirate effectue sur Fa0/20** **Mac Flooding stoppé sur SW1**  
**du SW0 du Mac Flooding** **pas d'écoute du trafic sur SW1**  
**trafic SW0 écouté !** **sauf si destination vers SW0...**

| VLAN | Mac Address    | Port               |
|------|----------------|--------------------|
| 1    | 00D0.D38C.6319 | GigabitEthernet0/1 |
| 1    | AAAA.BBBB.0000 | FastEthernet0/20   |
| 1    | AAAA.BBBB.0001 | FastEthernet0/20   |
| 1    | AAAA.BBBB.0002 | FastEthernet0/20   |
| 1    | AAAA.BBBB.0003 | FastEthernet0/20   |

| VLAN | Mac Address    | Port               |
|------|----------------|--------------------|
| 1    | 0003.E47C.5219 | GigabitEthernet0/1 |
| 1    | 0010.0010.0010 | GigabitEthernet0/1 |
| 1    | 0020.0020.0020 | GigabitEthernet0/1 |
| 1    | 0030.0030.0030 | GigabitEthernet0/1 |

de la sécurité sur tous les switch  
ne pas laisser de Fa0/x « ouvert » !



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

# PAUSE ?



10 minutes  
au maximum !





## SÉANCE n°1



BUT R&T  
Ressource R4.Cyber.09

# 1 – Attaques par inondation du réseau

## 1-g-1/ Causes et conséquences :

configurations incorrectes / dysfonctionnement réseau/hôte  
attaques intentionnelles par déni de service

**inondation du réseau par des tempêtes de trafic**



possibilité d'activer des fonctions sur les commutateurs :

- définir une tempête de trafic afin de l'identifier (notion de seuils)
- contrôler les tempêtes broadcast, uni/multicast (storm control)
- prendre les mesures appropriées : configuration sur le port
- vérifier le contrôle des tempêtes

## 1-g-2/ Notions de storm control :

**inondation du réseau local par un trafic excessif**

**dégradation des performances du réseau**

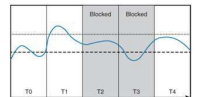
empêcher les ports réseau d'être perturbés par une tempête  
protéger par un contrôle des tempêtes de trafic

méthode :

- surveillance du trafic entrant sur un intervalle de temps (1s)
- comparaison du niveau trafic avec un niveau seuil « tempête »
- niveau = bps ou paquets/s ou % bande passante totale du port
- deux niveau de seuil possibles (seuil bas optionnel) :

seuil haut : blocage du port au prochain intervalle de temps

seuil bas : déblocage du port au prochain intervalle de temps



## SÉANCE n°1



BUT R&T  
Ressource R4.Cyber.09

# 1 – Attaques par inondation du réseau

## 1-g-3/ Alternative contrôle de tempêtes :

configuration sur les ports d'accès des commutateurs

limite les effets des tempêtes avant l'accès au LAN

possibilité de contrôler les tempêtes sur un lien multiVLAN

configuration par interfaces pour chaque type de trafic

trafic : unicast, multicast et broadcast (parfois groupés)

étapes de configuration :

- configurer un seuil montant (haut)
- configurer éventuellement le seuil descendant (bas)
- définir pour chaque seuil le %BP(level) ou en bps ou en pps

définition de seuils pertinents nécessite une surveillance de l'interface sur une longue période afin de les ajuster si nécessaire.

```
SW(conf)#interface Fa0/1
SW(con-if)#storm-control [broadcast | multicast | unicast] [level | bps | pps] [level | bps | pps]
```

type de trafic                      seuil haut                      seuil bas

- définir des actions supplémentaires si dépassement de seuil

```
SW(con-if)#storm-control action {shutdown | trap} (désactivation et/ou piège SNMP)
```

### Exemple :

seuil bas de 5% et haut de 25% pour le broadcast

seuil bas de 15000pps et haut de 40000pps pour le multicast

seuil haut de 20Mbps pour le trafic unicast

état shutdown pour les ports en dépassement de seuil

envoi d'une annonce SNMP si les seuils sont atteints



utilisation d'outils tels iPerf afin de générer du trafic et tester le contrôle des tempêtes

```
SW(conf-if)#storm-control broadcast level 25 5
SW(conf-if)#storm-control multicast level pps 40k 15k
SW(conf-if)#storm-control unicast level bps 20m
SW(conf-if)#storm-control action shutdown
SW(conf-if)#storm-control action trap
```

```
SW#show storm-control (broad/multicast/unicast)
interface Filter State Upper Lower Current
-----
Fa0/1 Forward 25.00% 5.00% 4.00%
Fa0/1 Blocking 40k pps 15k pps 25k pps
Fa0/1 Blocking 20m bps 20m bps 25m bps
```



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 2 - Attaque par Vlan

### 2-a/ Utilisation du protocole DTP

Rappels concernant DTP :

- *protocole propriétaire Cisco Dynamic Trunk Protocol*
- *permet de gérer dynamiquement l'activation/désactivation d'un « trunk »*
- *ports du commutateur configurés en négociation automatique par défaut !*
- *ils passent en mode « access » ou « trunk » selon l'autre extrémité*
- *faille : exploiter cette facilité afin d'usurper un trunk légitime*

**auto** : attend une sollicitation pour passer en trunk  
**desirable** : annonce la volonté de passer en trunk  
**trunk** : mode trunk en informant le switch voisin  
**nonegotiate** : désactivation du protocole DTP



|                                                   |                       |                                                   |
|---------------------------------------------------|-----------------------|---------------------------------------------------|
| SW1(conf)#interface Fa0/1                         |                       | SW2(conf)#interface Fa0/2                         |
| SW1(conf-if)#switchport mode dynamic auto         | mode                  | SW2(conf-if)#no switchport mode dynamic auto      |
| SW1#show interfaces trunk                         | Null - access - Null  | SW2(conf-if)#switchport mode accès                |
|                                                   |                       | SW2(conf-if)#switchport trunk encapsulation dot1q |
| SW1#show interfaces trunk                         | Fa0/1 - trunk - Fa0/2 | SW2(conf-if)#switchport mode trunk                |
| SW1#show interfaces trunk                         | Null - access - Null  | SW2(conf-if)#no switchport mode trunk             |
|                                                   | Fa0/1 - trunk - Fa0/2 | SW2(conf-if)#switchport mode dynamic desirable    |
| SW1#show interfaces trunk                         | Null - access - Null  | SW2(conf-if)#no switchport mode dynamic           |
| SW1(conf-if)#switchport nonegotiate               | Null - access - Null  | SW2(conf-if)#switchport mode access               |
| SW1(conf-if)#switchport trunk encapsulation dot1q |                       |                                                   |
| SW2(conf-if)#switchport mode trunk                | Fa0/1 - trunk - Fa0/2 | SW2(conf-if)#switchport nonegotiate               |
|                                                   |                       | SW2(conf-if)#switchport mode trunk                |

La désactivation du protocole DTP impose de forcer les extrémités du lien entre deux commutateurs soit en mode « access », soit en mode « trunk ».



## SÉANCE n°1



BUT R&T

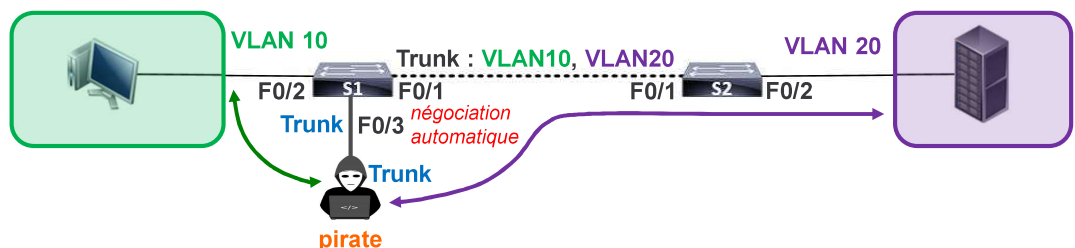
Ressource R4.Cyber.09

## 2 - Attaque par Vlan

### 2-b/ Exemple du Switch spoofing

Objectif de l'usurpation de Vlan :

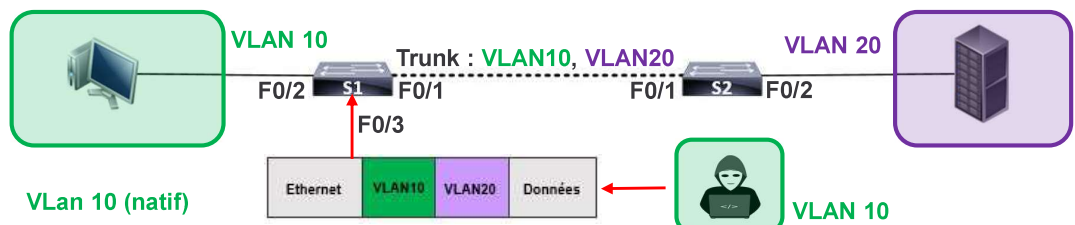
- *établir une liaison « trunk » avec un autre commutateur*
- *recupérer le trafic étiqueté du réseau*



### 2-c/ Exemple du Double tagging (part1)

Méthode utilisée pour le Vlan hopping :

- *utiliser frauduleusement la configuration du Vlan natif*
- *permettre de communiquer avec une machine en dehors de son Vlan*
- *identifier une trame pour le Vlan natif et insérer un second tag de Vlan*
- *le second tag de Vlan est celui du Vlan ciblé par l'attaque*







## SÉANCE n°1



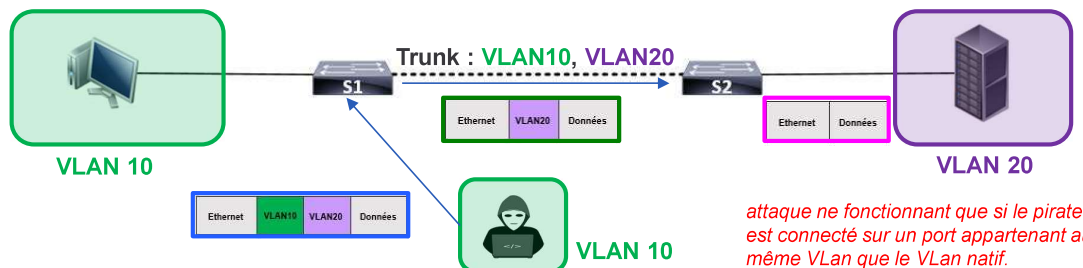
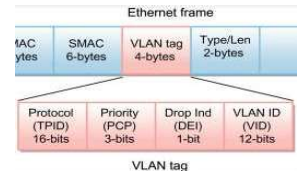
BUT R&T  
Ressource R4.Cyber.09

## 2 - Attaque par Vlan

### 2-c/ Exemple du Double tagging (part2)

Modalités et conséquence du Vlan hopping :

- les commutateurs réalisent un seul niveau de désencapsulation 802.1q
- le pirate intègre une étiquette 802.1q à l'intérieur de la trame
- permet une transmission vers un Vlan non spécifié par le tag d'origine
- modalités :
  - le pirate envoie une trame 802.1q avec deux tags au commutateur
  - l'en-tête externe est le tag ajouté par le pirate, identique au Vlan natif du port trunk
  - l'en-tête interne concerne le Vlan ciblé par le pirate
  - le commutateur vérifie le premier tag de 4 octets
  - il détecte que la trame est destinée au Vlan natif
  - il retire l'étiquette (ici Vlan10)
  - il transmet la trame à tous les ports du Vlan10
  - sur le trunk, la trame du Vlan natif n'est pas taguée à nouveau
  - le tag Vlan20 est inchangée et non inspectée
  - le second commutateur reçoit la trame et examine le tag placé par le pirate
  - Il envoie la trame sur le port cible et la diffuse si pas d'entrée dans la table @MAC



attaque ne fonctionnant que si le pirate est connecté sur un port appartenant au même Vlan que le Vlan natif.



## SÉANCE n°1



BUT R&T  
Ressource R4.Cyber.09

## 2 - Attaque par Vlan

### 2-d/ Alternatives :

DTP = dynamic trunk protocol (cisco)  
LLDP = link layer discovery protocol (autre)

Contre-mesures à déployer :

- désactiver tous les ports non utilisés à placer dans un Vlan inutilisé
- désactiver la négociation **DTP** sur les ports d'accès (conf-if)#switchport mode access
- lien multiVlan :
  - activer manuellement le mode « trunk »  
(conf-if)#switchport mode trunk
  - désactiver la négociation DTP (LLDP)  
(conf-if)#switchport nonegociate
  - définir un **Vlan natif** autre que celui par défaut  
(conf-if)#switchport trunk native vlan ?

```
SW(conf)#
SW(conf)#vlan 1000
SW(conf-vlan)#name POUBELLE
SW(conf)#vlan 999
SW(conf-vlan)#name NATIF
!
SW(conf)#interface range Fa0/6 - 9,Fa0/16 - 19
SW(conf-if-range)#switchport mode access
SW(conf-if-range)#switchport access vlan 1000
SW(conf-if-range)#shutdown
SW(conf-if-range)#exit
!
SW(conf)#interface range Fa0/1 - 5,Fa0/10 - 15
SW(conf-if-range)#switchport mode access
SW(conf-if-range)#shutdown
SW(conf-if-range)#exit
!
SW(conf)#interface range Fa0/20 - 24
SW(conf-if-range)#switchport trunk encapsulation dot1q
SW(conf-if-range)#switchport mode trunk
SW(conf-if-range)#switchport nonegociate
SW(conf-if-range)#switchport trunk native vlan 999
SW(conf-if-range)#switchport trunk allowed vlan remove 999
SW(conf)#vlan dot1q tag native
```

définition des Vlan

Vlan natif est le vlan dans lequel sont transmises les trames non taguées comme celles du protocole CDP et DTP. Il est identique aux extrémités d'un trunk

sécurisation des ports non utilisés

sécurisation des ports d'accès

sécurisation des ports d'extrémité de liens multiVlan.  
il est recommandé que le Vlan natif n'ait aucun port affecté et qu'il soit aussi tagué !



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 2 – Attaque au sein d'un même VLAN

### 2-e/ Limitations des VLAN

Un VLAN est un domaine de broadcast

Tous les équipements d'un même VLAN se voient

Un VLAN « invité » va réunir tous les utilisateurs connectés  
*mais les utilisateurs ne désirent pas forcément échanger entre eux  
 ils ont juste besoin d'accéder à la passerelle pour l'accès Internet  
 les utilisateurs doivent être isolés entre eux*

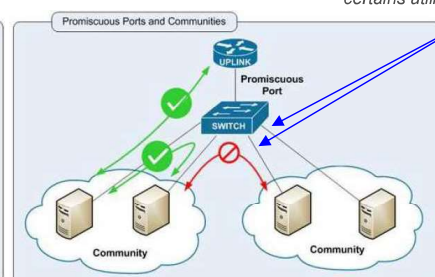
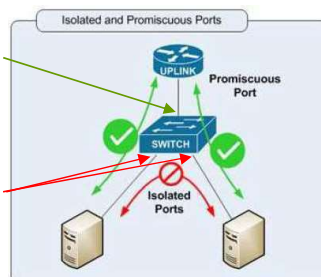
Les serveurs d'un même VLAN sont visibles les uns des autres  
*les serveurs font partis d'une communauté comme la DMZ  
 un serveur est attaqué, la porte est ouverte vers les autres serveurs*

Un FAI fournit un accès à des clients visibles entre eux  
*même réseau mais un compartimentage est pourtant nécessaire*

### 2-f/ Alternative : les PVLAN

ports mode **promiscuous**  
 partage le trafic  
 accède à la passerelle  
 par le VLAN **primaire**

ports mode **isolated**  
 même VLAN  
 accède à la même  
 passerelle  
 ne se voient pas



ports mode **community**  
 même VLAN **secondaire**  
 accède à la même passerelle  
 certains utilisateurs se voient



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 2 – Attaque au sein d'un même VLAN

### 2-g/ Fonctionnement des PVLAN

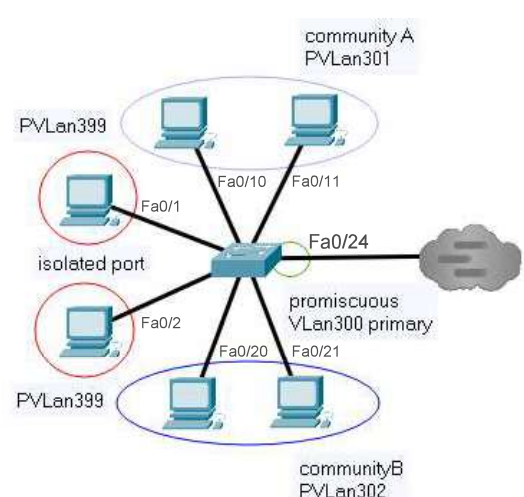
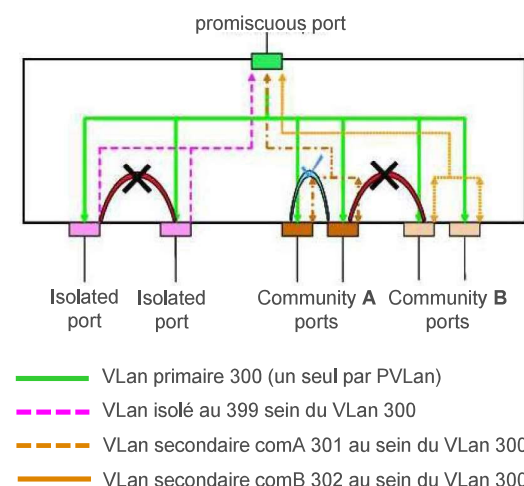
Trois types de configuration des PVLAN :

- **isolated** : communique uniquement avec le VLAN primaire
- **community** : communique avec host même communauté et VLAN primaire
- **primary** : communique avec les Vlan (isolated et community)

Deux modes de configuration au niveau de l'interface :

- **host** : mode « private-vlan host » pour les vlan isolated et community
- **promiscuous** : mode « private-vlan promiscuous » pour les vlan primary

Exemple :







## SÉANCE n°1



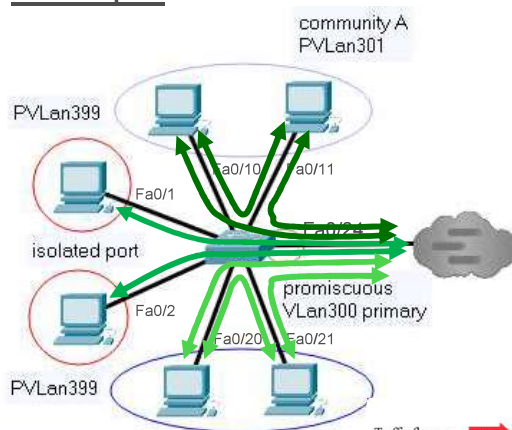
BUT R&T

Ressource R4.Cyber.09

## 2 – Attaque au sein d'un même Vlan

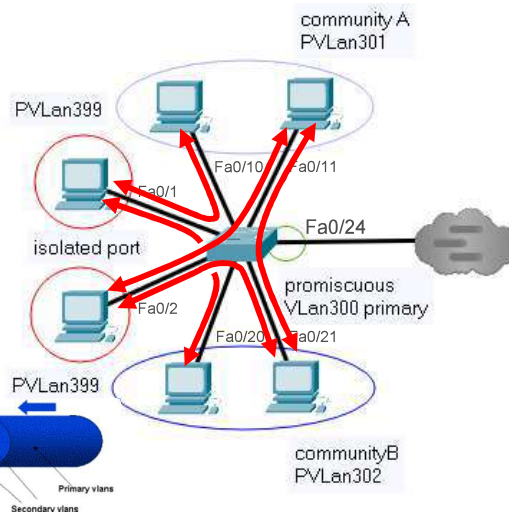
### 2-h/ Analyse des flux et configurations

Exemple : **autorisés**



```
SW(conf)#vtp mode transparent
SW(conf)#vtp domain RT
SW(conf)#vtp password IloveRT
SW(conf)#vlan 300
SW(conf-vlan)#name PRIMAIRE
SW(conf-vlan)#private-vlan primary
SW(conf-vlan)#private-vlan association 301,302,399
SW(conf)#vlan 301
SW(conf-vlan)#name SECONDAIRE1_300
SW(conf-vlan)#private-vlan community
SW(conf)#vlan 302
SW(conf-vlan)#name SECONDAIRE2_300
SW(conf-vlan)#private-vlan community
SW(conf)#vlan 399
SW(conf-vlan)#name ISOLE
SW(conf-vlan)#private-vlan isolated
```

**interdits**



```
SW(conf)#interface range Fa0/1 - 2
SW(conf-range)#switchport mode private-vlan host
SW(conf-range)#switchport private-vlan host-association 300 399
SW(conf)#interface range Fa0/10 - 11
SW(conf-range)#switchport mode private-vlan host
SW(conf-range)#switchport private-vlan host-association 300 301
SW(conf)#interface range Fa0/20 - 21
SW(conf-range)#switchport mode private-vlan host
SW(conf-range)#switchport private-vlan host-association 300 302
!
SW(conf)#interface Fa0/24
SW(conf-if)#switchport mode private-vlan promiscuous
SW(conf-if)#switchport private-vlan mapping 300-302,399
```



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 2 – Attaque au sein d'un même Vlan

### 2-i-1/ Application (topologie)

Tous les hôtes appartiennent au **Vlan100**, mais sont répartis selon deux communautés **11** et **12**. Les hôtes doivent accéder au serveur FTP. Seule la communauté **12** est autorisée à accéder au cœur de réseau pour une liaison vers Internet. Tous les autres ports des SW d'accès sont **isolés** mais doivent accéder à Internet.

Vlan100 : Vlan primaire

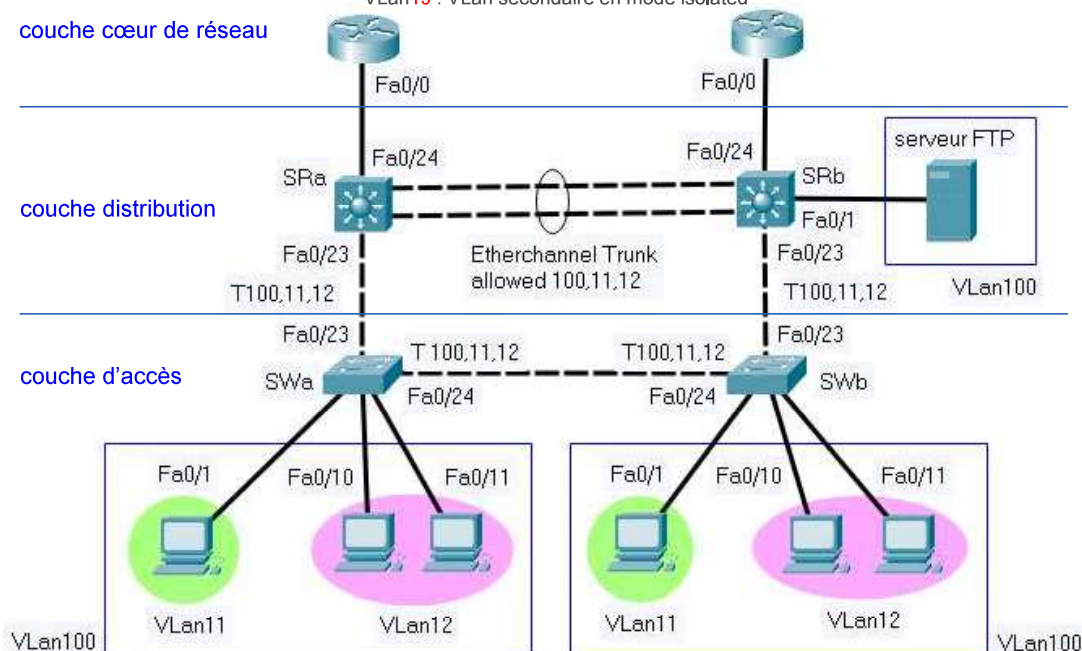
Vlan11-12 : Vlan secondaire en mode community

Vlan19 : Vlan secondaire en mode isolated

couche cœur de réseau

couche distribution

couche d'accès





# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 2 – Attaque au sein d'un même Vlan

### 2-i-2/ Application (configuration)

```
SWa(conf)#vtp mode transparent
SWa(conf)#vtp domain RT
SWa(conf)#vtp password llovert
```

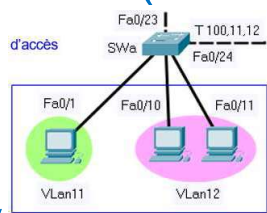
```
!
SWa(conf)#vlan 100
SWa(conf-vlan)#name PRIMAIRE
SWa(conf-vlan)#private-vlan primary
SWa(conf-vlan)#private-vlan association 11,12,19
```

```
!
SWa(conf)#vlan 11
SWa(conf-vlan)#name SECONDAIRE1_100
SWa(conf-vlan)#private-vlan community
SWa(conf)#vlan 12
SWa(conf-vlan)#name SECONDAIRE2_100
SWa(conf-vlan)#private-vlan community
SWa(conf)#vlan 19
SWa(conf-vlan)#name ISOLE
SWa(conf-vlan)#private-vlan isolated
```

```
!
SWa(conf)#interface range Fa0/1
SWa(conf-range)#switchport mode private-vlan host
SWa(conf-range)#switchport private-vlan host-association 100 11
SWa(conf)#interface range Fa0/10 - 11
SWa(conf-range)#switchport mode private-vlan host
SWa(conf-range)#switchport private-vlan host-association 100 12
```

```
!
SWa(conf)#interface Fa0/24
SWa(conf-if)#switchport mode trunk
SWa(conf-if)#switchport trunk allowed vlan 100
SWa(conf-if)#switchport mode private-vlan promiscuous
SWa(conf-if)#switchport private-vlan mapping 100, 11-12, 19
```

```
!
SWa(conf)#interface Fa0/23
SWa(conf-if)#switchport mode trunk
SWa(conf-if)#switchport trunk allowed vlan 100
SWa(conf-if)#switchport mode private-vlan promiscuous
SWa(conf-if)#switchport private-vlan mapping 100, 11-12, 19
```



```
SRb(conf)#vtp mode transparent
SRb(conf)#vtp domain RT
SRb(conf)#vtp password llovert
```

```
!
SRb(conf)#vlan 100
SRb(conf-vlan)#name PRIMAIRE
SRb(conf-vlan)#private-vlan primary
SRb(conf-vlan)#private-vlan association 11,12,19
```

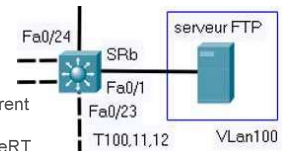
```
!
SRb(conf)#vlan 11
SRb(conf-vlan)#name SECONDAIRE1_100
SRb(conf-vlan)#private-vlan community
SRb(conf)#vlan 12
SRb(conf-vlan)#name SECONDAIRE2_100
SRb(conf-vlan)#private-vlan community
SRb(conf)#vlan 19
SRb(conf-vlan)#name ISOLE
SRb(conf-vlan)#private-vlan isolated
```

```
!
SRb(conf)#interface Fa0/23
SRb(conf-if)#switchport mode trunk
SRb(conf-if)#switchport trunk allowed vlan 100
SRb(conf-if)#switchport mode private-vlan promiscuous
SRb(conf-if)#switchport private-vlan mapping 100,11-12,19
```

```
!
SRb(conf)#interface Fa0/1
SRb(conf)#switchport mode access
SRb(conf)#switchport access vlan 100
SRb(conf-if)#switchport mode private-vlan promiscuous
SRb(conf-if)#switchport private-vlan mapping 100,11-12,19
```

```
!
SRb(conf)#interface Fa0/24
SRb(conf-if)#switchport mode trunk
SRb(conf-if)#switchport trunk allowed vlan 100
SRb(conf-if)#switchport mode private-vlan promiscuous
SRb(conf-if)#switchport private-vlan mapping 100,11-12,19
```

Le PVlan11 ne passe pas vers Internet



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 3- Attaque DHCP

### 3-a-1/ Le principe du DHCP Spoofing :

usurpation d'identité en répondant aux demandes DHCP se faire passer pour la passerelle ou le serveur DNS défaut

### 3-a-2/ La conséquence : Man In The Middle

réponse aux requêtes DHCP avec de fausses informations  
interception du trafic par le serveur DHCP non légitime  
redirection du trafic vers la vraie passerelle  
tous les paquets utilisant le DNS ou sortants sont écoutés

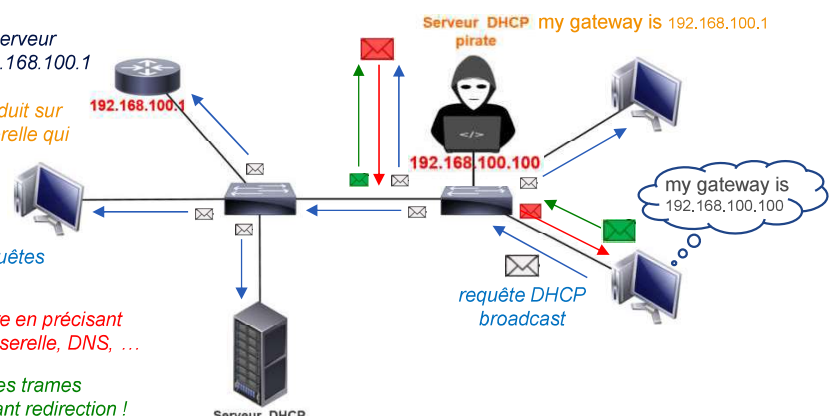
Soit un réseau LAN avec un serveur DHCP et la passerelle en 192.168.100.1

Un serveur DHCP pirate s'introduit sur le réseau annonçant une passerelle qui est lui-même.

Le serveur pirate reçoit les requêtes DHCP des utilisateurs du LAN

Le serveur pirate émet une offre en précisant des données fallacieuses : passerelle, DNS, ...

L'utilisateur trompé envoie ses trames vers la fausse passerelle avant redirection !







## SÉANCE n°1



BUT R&T  
Ressource R4.Cyber.09

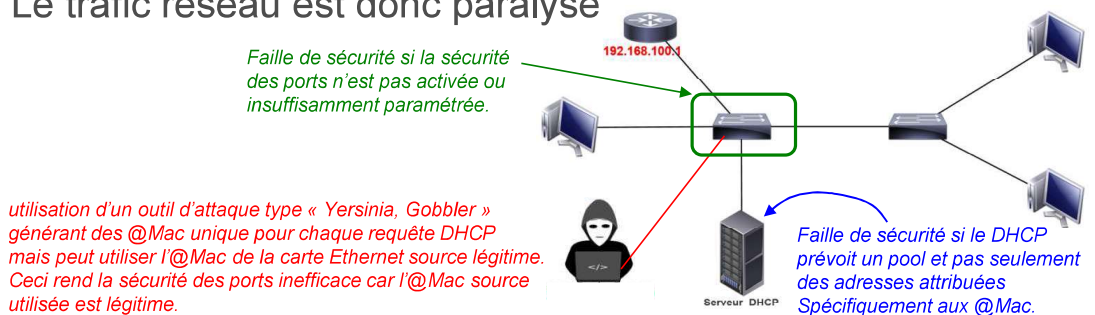
### 3- Attaque DHCP

#### 3-b-1/ Le principe du DHCP Starvation :

obtenir la famine chez les utilisateurs par l'absence d'@IP  
déclenche une attaque de l'homme du milieu (**man in the middle**)  
attaque ciblant le serveur DHCP légitime du réseau  
déni de service (**DoS**) en inondant le vrai serveur DHCP  
multiplicité de DHCP-request en utilisant des @Mac spoofées

#### 3-b-2/ La conséquence :

le serveur DHCP répond à toutes les demandes  
les demandes épuisent les ressources en adresses IP  
plus de possibilité d'attribuer des adresses (pool entier délivré)  
les utilisateurs sans paramètre IP ne peuvent communiquer  
Le trafic réseau est donc paralysé



## SÉANCE n°1



BUT R&T  
Ressource R4.Cyber.09

### 3- Attaque DHCP

#### 3-c/ Alternative : la surveillance DHCP

paramétrer la sécurité des ports des commutateurs  
compléter par une surveillance DHCP sur des ports **approuvés**  
filtrage des messages DHCP *sur une liaison trunk ou un port connecté au serveur DHCP*  
limitation du trafic DHCP sur les ports **non approuvés**

principe de base :

équipements réseaux sous contrôle administratif = **sources fiables**  
interfaces spécifiques (serveurs, jonctions) = ports sécurisés  
périphériques hors réseau et tous autres ports = **sources non fiables**

création d'une table de correspondance DHCP :

activation de la surveillance permet la création d'une table  
**correspondance** entre @Mac sur port non approuvé et @IP délivrées  
table appelée : **table de liaison d'espionnage DHCP**

commande Switch#show ip dhcp snooping binding

| Switch#sh ip dhcp snooping bind |                |            |               |      |                  |
|---------------------------------|----------------|------------|---------------|------|------------------|
| MacAddress                      | IpAddress      | Lease(sec) | Type          | VLAN | Interface        |
| 00:00:11:11:01:00               | 192.168.10.100 | 86400      | dhcp-snooping | 1    | FastEthernet0/10 |
| 00:00:11:11:01:01               | 192.168.10.101 | 86400      | dhcp-snooping | 1    | FastEthernet0/11 |
| 00:00:11:11:01:02               | 192.168.10.102 | 86400      | dhcp-snooping | 1    | FastEthernet0/12 |
| Total number of bindings: 3     |                |            |               |      |                  |

*ports non approuvés*



# SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 3- Attaque DHCP

### 3-d/ Exercice de sécurisation (part1)

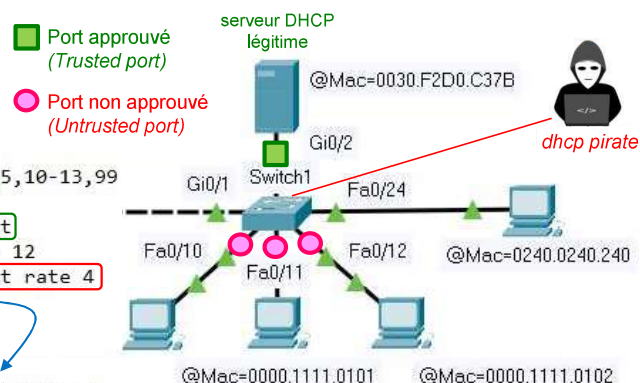
Rappel des commandes :

- (conf)#**ip dhcp snooping** active la surveillance dhcp sur l'équipement
- (conf-if)# **ip dhcp snooping trust** approuve un port fiable
- (conf-if)# **ip dhcp snooping limit rate « x »** limite un port non fiable  
x est défini en nombre de paquets par seconde
- (conf)#**ip dhcp snooping vlan « y »** active surveillance dhcp / VLAN

```
Switch#configure terminal
Switch(conf)#ip dhcp snooping
Switch(conf)#ip dhcp snooping vlan 1,5,10-13,99
Switch(conf)#interface Gi0/2
Switch(conf-if)#ip dhcp snooping trust
Switch(conf)#interface range Fa0/10 - 12
Switch(conf-if)#ip dhcp snooping limit rate 4
Switch#show ip dhcp snooping
Switch#show ip dhcp snooping binding
```

```
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs : 7
Insertion of option 82 is enabled
Verification of hwaddr field is enabled
```

| Interface          | Trusted | Rate limit (pps) |
|--------------------|---------|------------------|
| GigabitEthernet0/2 | yes     | unlimited        |
| FastEthernet0/10   | no      | 4                |
| FastEthernet0/11   | no      | 4                |
| FastEthernet0/12   | no      | 4                |



Analyse : la surveillance dhcp est activée sur SW1 ainsi que sur tous les VLAN. Le port connecté au vrai serveur dhcp est **approuvé** alors que les autres ports ne le sont pas. Ces derniers sont donc **limités** à 4 paquets par seconde concernant la requête dhcp.

Le port sur lequel est connecté le pirate n'est pas approuvé, il ne recevra pas les requêtes dhcp des utilisateurs !



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 3- Attaque DHCP

### 3-d/ Exercice de sécurisation (part2)

Topologie d'étude :

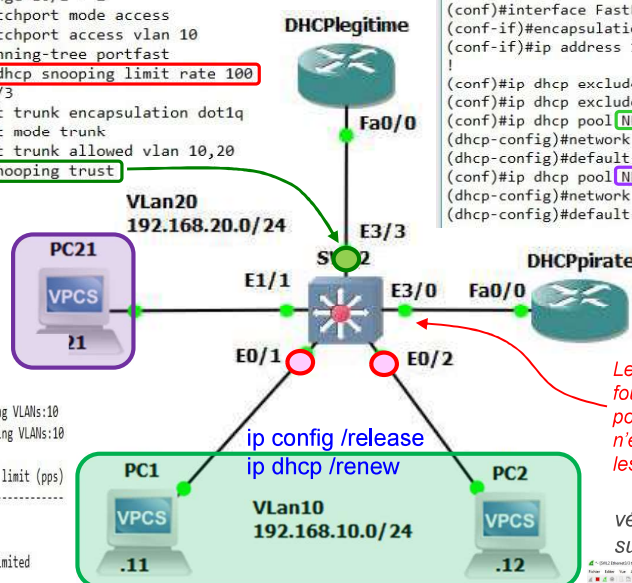
```
SWL2(conf)#ip dhcp snooping
SWL2(conf)#ip dhcp snooping vlan 10
SWL2(conf)#interface range E0/1 - 2
SWL2(conf-if-range)#switchport mode access
SWL2(conf-if-range)#switchport access vlan 10
SWL2(conf-if-range)#spanning-tree portfast
SWL2(conf-if-range)#ip dhcp snooping limit rate 100
SWL2(conf)#interface E3/3
SWL2(conf-if)#switchport trunk encapsulation dot1q
SWL2(conf-if)#switchport mode trunk
SWL2(conf-if)#switchport trunk allowed vlan 10,20
SWL2(conf-if)#ip dhcp snooping trust
```

```
SWL2#sh ip dhcp snooping
Switch DHCP snooping is enabled
Switch DHCP learning is disabled
DHCP snooping is configured on following VLANs:10
DHCP snooping is operational on following VLANs:10
```

| Interface   | Trusted | Allow option | Rate limit (pps) |
|-------------|---------|--------------|------------------|
| Ethernet0/1 | no      | no           | 100              |
| Ethernet0/2 | no      | no           | 100              |
| Ethernet3/3 | yes     | yes          | unlimited        |

```
SWL2#sh ip dhcp snooping binding
MacAddress IpAddress Lease(sec) Type VLAN Interface
-----
7C:C2:C6:19:CF:69 192.168.10.4 85752 dhcp-snooping 10 Ethernet0/1
7C:C2:C6:19:CA:AA 192.168.10.3 85733 dhcp-snooping 10 Ethernet0/2
Total number of bindings: 2
```

Le dhcp pour le VLAN20 ne fonctionne pas tant que le snooping sur ce VLAN n'est pas activé

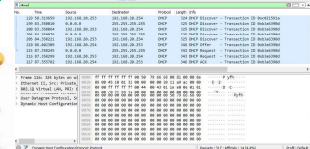


Le dhcp du Pirate ne pourra fournir une affectation car le port sur lequel il est connecté n'est pas approuvé (no trust) les offres dhcp sont arrêtées !!!

vérification par Wireshark sur chacun des liens E3/3-3

```
(conf)#interface FastEthernet0/0
(conf-if)#no shutdown
(conf)#interface FastEthernet0/0.10
(conf-if)#encapsulation dot1q 10
(conf-if)#ip address 192.168.10.254 255.255.255.0
(conf)#interface FastEthernet0/0.20
(conf-if)#encapsulation dot1q 20
(conf-if)#ip address 192.168.20.254 255.255.255.0
!
(conf)#ip dhcp excluded-address 192.168.10.254
(conf)#ip dhcp excluded-address 192.168.20.254
(conf)#ip dhcp pool NET192.168.10.0
(dhcp-config)#network 192.168.10.0 255.255.255.0
(dhcp-config)#default-router 192.168.10.254
(conf)#ip dhcp pool NET192.168.20.0
(dhcp-config)#network 192.168.20.0 255.255.255.0
(dhcp-config)#default-router 192.168.20.254
```

et les VACL alors ?







## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

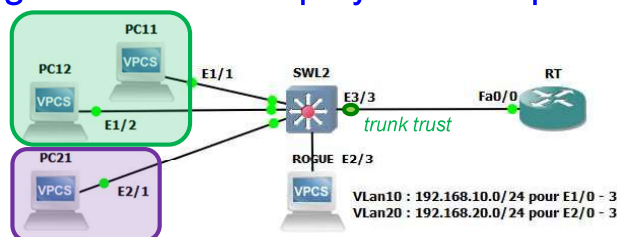
### 3- Attaque par usurpation d'@IP

#### 3-e-1/ Contexte de l'IP spoofing

les équipements ont besoin d'une @IP pour communiquer  
usurpation d'une @IP provenant d'un hôte ou serveur valide  
**difficulté d'interdire et de détecter l'IP spoofing a posteriori**  
anticiper l'IP spoofing en utilisant le DHCP snooping

#### 3-e-2/ Alternative : IPSG

faire appel à la fonctionnalité IP Source Guard  
permet une première contre-mesure contre l'IP spoofing  
se base sur la table de liaison d'espionnage DHCP  
établit dynamiquement des PACL sur les ports concernés  
bloque trafic IP sur un port si pas de correspondance / table  
empêche connexion d'un autre hôte sur le port avec même IP  
à déployer essentiellement sur les ports d'accès  
peut également être déployé sur les ports trunk



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

### 3- Attaque par usurpation d'@IP

#### 3-e-3/ Fonctionnement de l'IPSG

IPSG est pris en charge sur la couche 2 (ports access / trunk)  
marche en complément du DHCP snooping  
**ne s'intéresse pas aux ports éprouvés (trust)**  
applique dynamiquement PACL sur les ports non éprouvés  
utilise la table de liaison d'espionnage DHCP

deux niveaux de filtrage :

- **Source IP address filter** : correspondance avec les @IP renseignées dans la table d'espionnage pour le port considéré. Si table non alimentée pour le port, aucun trafic n'est permis. Suppression du filtre sur le port implique la suppression PACL
- **Source IP and MAC address filter** : correspondance avec les associations de triplets @IP/@MAC/port de la table afin d'autoriser le trafic du hôte sur le port.

#### 3-e-4/ Configuration et tests

mettre en place le DHCP snooping sur les VLAN  
identifier les interfaces éprouvées (trunk et serveurs)

filtrer sur l'@IP source seule : (conf-if)#ip verify source

filtrer sur @IP/MAC source : (conf-if)#ip verify source port-security



## SÉANCE n°1



BUT R&T  
Ressource R4.Cyber.09

# 3- Attaque par usurpation d'@IP

## 3-e-5/ Application (part1)

```
SWL2(config)#int range E1/1,E1/2,E2/1
SWL2(config-if-range)#ip verify source
```

1-activation de l'IPSG sur les ports d'accès

```
SWL2#clear ip dhcp snooping binding *
SWL2#sh ip dhcp snooping binding
```

effacement table de liaison d'espionnage  
affichage table de liaison d'espionnage

```
MacAddress      IPAddress      Lease(sec)    Type          VLAN  Interface
-----
Total number of bindings: 0
!
```

```
SWL2#sh ip verify source
```

affichage table IPSG

| Interface | Filter-type | Filter-mode | IP-address | Mac-address | Vlan |
|-----------|-------------|-------------|------------|-------------|------|
| Et1/1     | ip          | active      | deny-all   |             | 10   |
| Et1/2     | ip          | active      | deny-all   |             | 10   |
| Et2/1     | ip          | active      | deny-all   |             | 20   |

PACL active sur les ports  
interdisant tout trafic IP

2-requête DHCP des hôtes depuis les ports d'accès

```
SWL2#sh ip dhcp snooping binding
```

| MacAddress        | IPAddress    | Lease(sec) | Type          | VLAN | Interface   |
|-------------------|--------------|------------|---------------|------|-------------|
| 00:50:79:66:68:00 | 192.168.20.1 | 86362      | dhcp-snooping | 20   | Ethernet2/1 |
| 00:50:79:66:68:01 | 192.168.10.2 | 86395      | dhcp-snooping | 10   | Ethernet1/2 |
| 00:50:79:66:68:02 | 192.168.10.1 | 86352      | dhcp-snooping | 10   | Ethernet1/1 |

```
Total number of bindings: 3
!
```

```
SWL2#sh ip verify source
```

| Interface | Filter-type | Filter-mode | IP-address   | Mac-address | Vlan |
|-----------|-------------|-------------|--------------|-------------|------|
| Et1/1     | ip          | active      | 192.168.10.1 |             | 10   |
| Et1/2     | ip          | active      | 192.168.10.2 |             | 10   |
| Et2/1     | ip          | active      | 192.168.20.1 |             | 20   |

pas d'@MAC définies dans les  
PACL, le trafic est autorisé pour  
les associations IP/port



## SÉANCE n°1



BUT R&T  
Ressource R4.Cyber.09

# 3- Attaque par usurpation d'@IP

## 3-e-5/ Application (part2)

```
SWL2(config)#int range E1/1,E1/2,E2/1
```

```
SWL1#sh ip verify source
```

3-activation de l'IPSG avec port-security

```
SWL2(config-if-range)#ip verify source port-security
```

```
SWL2#sh ip dhcp snooping binding
```

| MacAddress        | IPAddress    | Lease(sec) | Type          | VLAN | Interface   |
|-------------------|--------------|------------|---------------|------|-------------|
| 00:50:79:66:68:00 | 192.168.20.1 | 86362      | dhcp-snooping | 20   | Ethernet2/1 |
| 00:50:79:66:68:01 | 192.168.10.2 | 86395      | dhcp-snooping | 10   | Ethernet1/2 |
| 00:50:79:66:68:02 | 192.168.10.1 | 86352      | dhcp-snooping | 10   | Ethernet1/1 |

```
Total number of bindings: 3
!
```

```
SWL2#sh ip verify source
```

| Interface | Filter-type | Filter-mode | IP-address   | Mac-address | Vlan |
|-----------|-------------|-------------|--------------|-------------|------|
| Et1/1     | ip-mac      | active      | 192.168.10.1 | permit-all  | 10   |
| Et1/2     | ip-mac      | active      | 192.168.10.2 | permit-all  | 10   |
| Et2/1     | ip-mac      | active      | 192.168.20.1 | permit-all  | 20   |

pas de restriction définie sur  
les ports par le port-security

```
interface Ethernet1/1
```

```
switchport access vlan 10
```

```
switchport mode access
```

```
switchport port-security maximum 2
```

```
switchport port-security violation restrict
```

```
switchport port-security mac-address sticky
```

```
switchport port-security mac-address 0050.7966.6802
```

```
switchport port-security
```

```
spanning-tree portfast edge
```

```
ip verify source port-security
```

```
ip dhcp snooping limit rate 100
```

4-configuration port-security sur le port E1/1



pour entrer, je dois connaître :  
- l'adresse IP de l'hôte usurpé  
- l'adresse MAC de l'hôte usurpé  
- le port de connexion

```
SWL2#sh ip verify source
```

| Interface | Filter-type | Filter-mode | IP-address   | Mac-address       | Vlan |
|-----------|-------------|-------------|--------------|-------------------|------|
| Et1/1     | ip-mac      | active      | 192.168.10.1 | 00:50:79:66:68:02 | 10   |
| Et1/2     | ip-mac      | active      | 192.168.10.2 | permit-all        | 10   |
| Et2/1     | ip-mac      | active      | 192.168.20.1 | permit-all        | 20   |





## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

### 3- Attaque par usurpation d'@MAC

#### 3-f-1/ Contexte du ARP Spoofing

les requêtes ARP sont nécessaires sur un réseau local  
elles sont initiées avant chaque application

les associations MAC/IP sont stockées dans un cache ARP

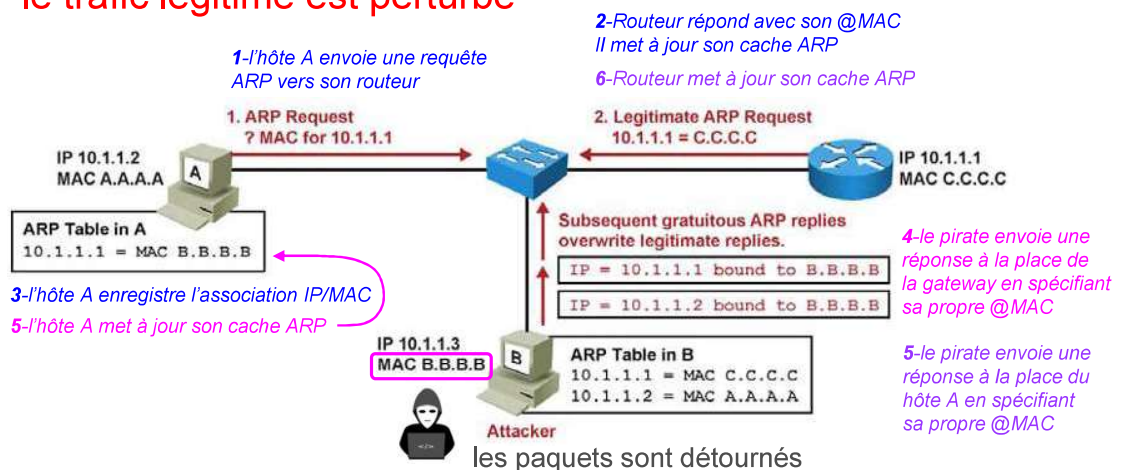
le maintien dans le cache dépend de l'équipement

usurpation consiste à remplacer une réponse ARP légitime

l'@MAC est donc remplacée par une @MAC invalide

en spécifiant l'@MAC gateway, trafic redirigé vers l'assaillant  
interception possible de certaines données critiques

le trafic légitime est perturbé



## SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

### 3- Attaque par usurpation d'@MAC

#### 3-f-2/ Alternative : Dynamic ARP inspection

objectif : lutter contre l'usurpation ou l'empoisonnement ARP  
seules les requêtes et réponses légitimes sont relayées

DAI laisse passer les requêtes sur les ports de confiance

DAI intercepte toutes les réponses sur les ports non éprouvés  
trame interceptée comparée à la table de liaison d'espionnage

si réponse non valide :

- elle peut être supprimée
- elle est enregistrée pour anticiper les attaques d'empoisonnement

DAI permet de limiter le débits des trames ARP sur les ports

consignes de configuration :

- tous les ports d'accès du commutateur comme non éprouvés
- les ports connectés à d'autres commutateurs comme éprouvés

#### 3-f-3/ Configuration

mécanisme en trois étapes :

- activez le DHCP snooping
- activez le DHCP snooping et le DAI sur les VLAN considérés
- configurez les interfaces éprouvées pour le DHCP et le DAI



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 3- Attaque par usurpation d'@MAC

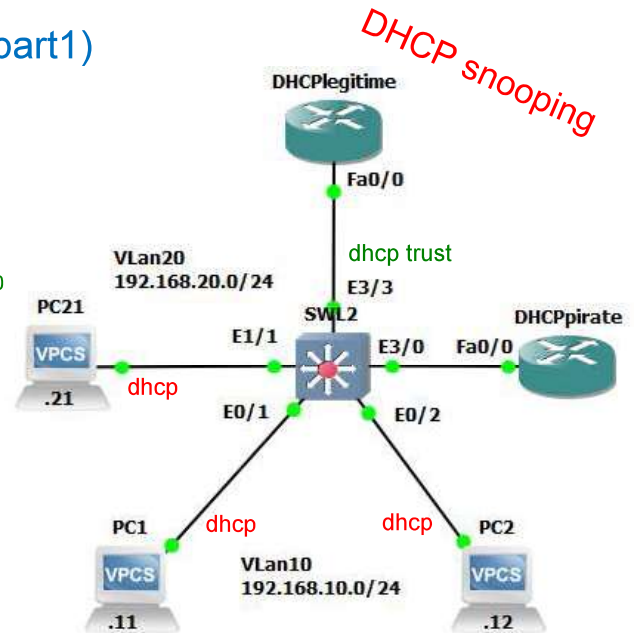
### 3-f-4/ Application (part1)

```
SWL2(conf)#ip dhcp snooping
SWL2(conf)#ip dhcp snooping vlan 10,20
!
SWL2(conf)#interface range Ethernet0/1 - 2
SWL2(conf-if-range)#switchport access vlan 10
SWL2(conf-if-range)#switchport mode access
SWL2(conf-if-range)#spanning-tree portfast
SWL2(conf-if-range)#ip dhcp snooping limit rate 100
!
SWL2(conf)#interface Ethernet1/1
SWL2(conf-if)#switchport access vlan 20
SWL2(conf-if)#switchport mode access
SWL2(conf-if)#spanning-tree portfast
```

```
!
SWL2(conf)#interface Ethernet3/0
SWL2(conf-if)#switchport trunk encapsulation dot1q
SWL2(conf-if)#switchport mode trunk
SWL2(conf-if)#switchport trunk allowed vlan 10,20
!
SWL2(conf)#interface Ethernet3/3
SWL2(conf-if)#switchport trunk encapsulation dot1q
SWL2(conf-if)#switchport mode trunk
SWL2(conf-if)#switchport trunk allowed vlan 10,20
SWL2(conf-if)#ip dhcp snooping trust
```

SWL2#sh ip dhcp snooping binding

| MacAddress                  | IpAddress     | Lease(sec) | Type          | VLAN | Interface   |
|-----------------------------|---------------|------------|---------------|------|-------------|
| 00:50:79:66:68:02           | 192.168.20.21 | 86390      | dhcp-snooping | 20   | Ethernet1/1 |
| 00:50:79:66:68:01           | 192.168.10.12 | 86297      | dhcp-snooping | 10   | Ethernet0/2 |
| 00:50:79:66:68:00           | 192.168.10.11 | 86341      | dhcp-snooping | 10   | Ethernet0/1 |
| Total number of bindings: 3 |               |            |               |      |             |



```
SWL2#sh ip arp inspection
Source Mac Validation : Disabled
Destination Mac Validation : Disabled
IP Address Validation : Disabled
No active or enabled vlans on switch.
```

création de la table de liaison d'espionnage



# SÉANCE n°1



BUT R&T

Ressource R4.Cyber.09

## 3- Attaque par usurpation d'@MAC

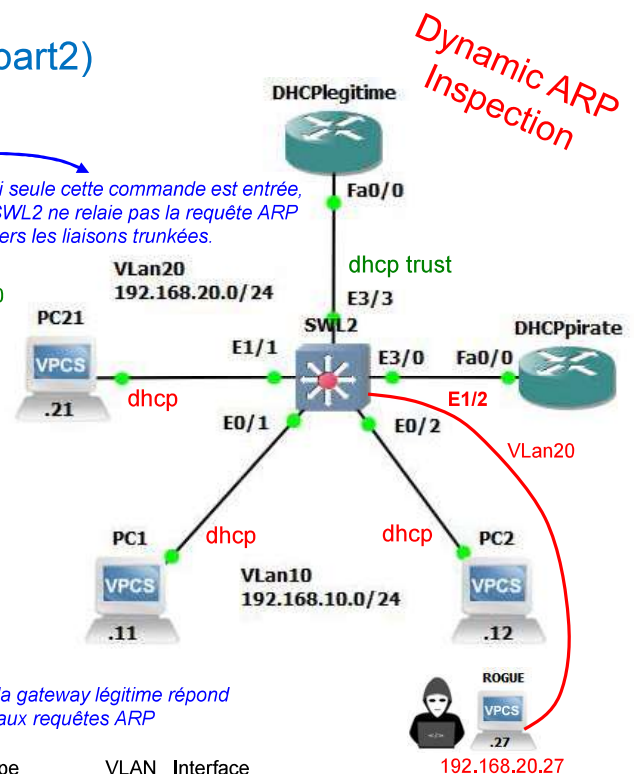
### 3-f-4/ Application (part2)

```
SWL2(conf)#ip dhcp snooping
SWL2(conf)#ip dhcp snooping vlan 10,20
SWL2(conf)#ip arp inspection vlan 10,20
!
SWL2(conf)#interface range Ethernet0/1 - 2
SWL2(conf-if-range)#switchport access vlan 10
SWL2(conf-if-range)#switchport mode access
SWL2(conf-if-range)#spanning-tree portfast
SWL2(conf-if-range)#ip dhcp snooping limit rate 100
!
SWL2(conf)#interface Ethernet1/1
SWL2(conf-if)#switchport access vlan 20
SWL2(conf-if)#switchport mode access
SWL2(conf-if)#spanning-tree portfast
```

```
!
SWL2(conf)#interface Ethernet3/0
SWL2(conf-if)#switchport trunk encapsulation dot1q
SWL2(conf-if)#switchport mode trunk
SWL2(conf-if)#switchport trunk allowed vlan 10,20
!
SWL2(conf)#interface Ethernet3/3
SWL2(conf-if)#switchport trunk encapsulation dot1q
SWL2(conf-if)#switchport mode trunk
SWL2(conf-if)#switchport trunk allowed vlan 10,20
SWL2(conf-if)#ip dhcp snooping trust
SWL2(conf-if)#ip arp inspection trust
```

SWL2#sh ip dhcp snooping binding

| MacAddress                  | IpAddress     | Lease(sec) | Type          | VLAN | Interface   |
|-----------------------------|---------------|------------|---------------|------|-------------|
| 00:50:79:66:68:02           | 192.168.20.21 | 86390      | dhcp-snooping | 20   | Ethernet1/1 |
| 00:50:79:66:68:01           | 192.168.10.12 | 86297      | dhcp-snooping | 10   | Ethernet0/2 |
| 00:50:79:66:68:00           | 192.168.10.11 | 86341      | dhcp-snooping | 10   | Ethernet0/1 |
| Total number of bindings: 3 |               |            |               |      |             |



pirate non référencé dans la table de liaison DHCP, ses requêtes et réponses ARP ne sont pas transmises

SWL2 fait remonter les trames invalides !



**Bachelor Universitaire de Technologie**  
**Réseaux & Télécommunications**

Code ressource : **R4.Cyber.09**  
**sécurité dans les LAN**



**PARTIE II**

Coefficient : 10/300 (UE44 : 8 – UE45 : 2)  
Heures encadrées : 13 heures dont 6h de TP  
CM : 6h – TP : 6h – DS : 1h  
Deux notes : **TP1** + **TP2** (coef.1) + **DS** (coef.1)

50



**SÉANCE**  
**n°2**



**BUT R&T**

Ressource R4.Cyber.09

**Sommaire :**

**PARTIE II : 3 heures de cours magistraux**

**4. Attaque par STP**

Conséquences du **Root spoofing** (usurpation) et du **DoS de BPDU**  
Alternative par les modes « **PortFast** » et « **BPDU Guard** »

**5. Attaque par SPAN/RSPAN**

Principe et conséquences du **Mirroring** (recopiage)  
Alternative par la sécurité des ports des commutateurs (**port security**)

**6. Sécurisation par utilisation des VACL/PACL**

Limitation des RACL (ACL au niveau des interfaces des routeurs)  
Principe de fonctionnement des **VACL** et interactions RACL/VACL/PACL **1h30**

**7. Sécurisation par authentification 802.1x** **1h30**

Limitation de Telnet et http : utilisation de SSHv2 et HTTPS  
Principe de l'architecture AAA (Authentication, Authorization, Accounting)  
Principe et configuration d'un serveur Radius  
Principe et configuration d'un serveur TACACS+



## SÉANCE n°2

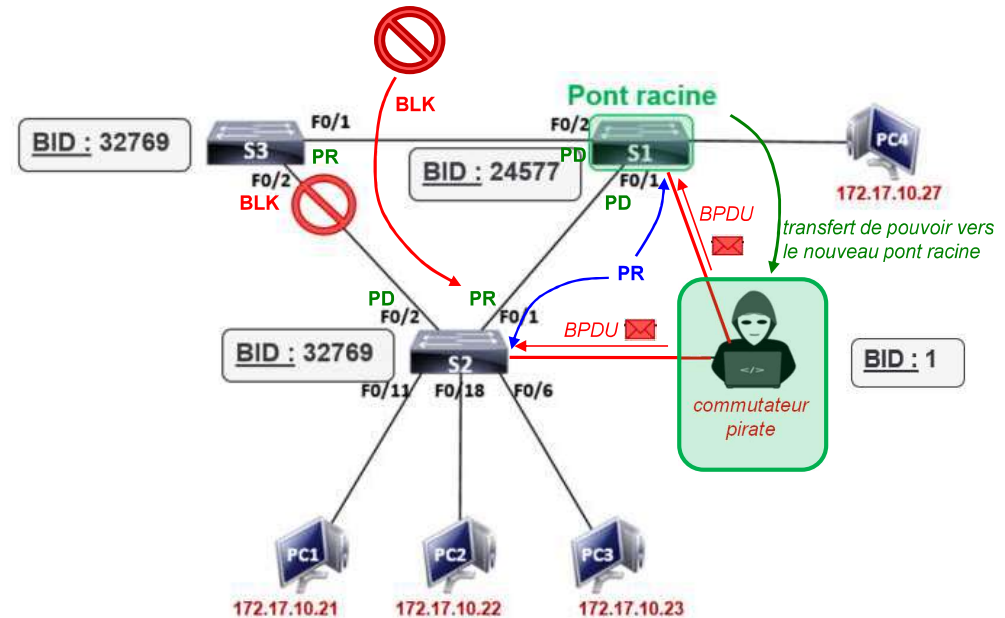


BUT R&T  
Ressource R4.Cyber.09

### 4 - Attaque STP

#### 4-a/ Récupération du rôle de ROOT :

un commutateur pirate envoie un **BPDU** dont le BID est faible  
les commutateurs recalculent l'arbre de recouvrement  
ils élisent le pirate comme étant la racine de l'arbre  
tout le trafic est donc redirigé automatiquement vers le pirate



## SÉANCE n°2

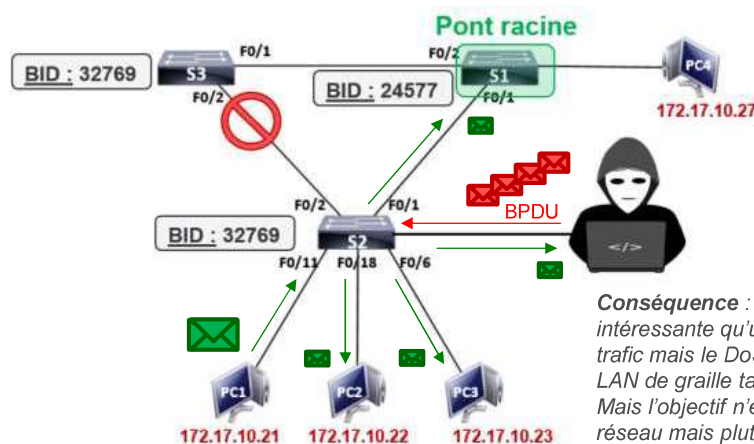


BUT R&T  
Ressource R4.Cyber.09

### 4 - Attaque STP

#### 4-b/ Réalisation d'un DoS :

un commutateur pirate inonde la topologie de **BPDU**  
la valeur de son **BID diminue progressivement**  
l'arbre de recouvrement est recalculé en permanence  
le processeur des commutateurs sont mobilisés  
la table d'@Mac est vidée à chaque fois  
**tout le trafic est redirigé vers tous les ports des commutateurs**



**Conséquence :** attaque DoS ne semble pas aussi intéressante qu'une redirection ou modification de trafic mais le DoS STP peut rendre inutilisable un LAN de taille sans savoir d'où cela provient. Mais l'objectif n'est pas forcément de faire chuter le réseau mais plutôt d'isoler certains équipements !

**IDS/IPS :** si une carte spécifique est placée dans un commutateur Root pour contrôler le trafic, il pourra être isolé et sa protection sera éliminée, le pirate pouvant accéder à une partie du réseau.

**Machines :** le pirate peut ainsi isoler les clients des serveurs afin d'usurper leurs identités et avoir accès aux informations du réseau.





## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 4- Attaque STP

## 4-c/ Alternative : (part1)

### Utilisation du mode PortFast :

port passe directement de l'état de blocage à l'état transmission  
les étapes d'écoute et d'apprentissage sont contournées  
les ports ne participent plus au calcul de l'arbre de recouvrement  
appliquer ce mode à **tous les ports reliant des utilisateurs feuilles**  
**ne pas appliquer sur les liaisons entre équipements (boucle)**

- (conf-if)#**spanning-tree portfast** active le mode sur l'interface
- (conf-if)#**spanning-tree portfast disable** désactive le mode sur l'interface
- (conf)#**spanning-tree portfast default** active le mode sur toutes interfaces

ne pas activer le mode  
sur les ports d'extrémité  
d'une liaison entre  
équipements actifs

L'activation par défaut  
impose de désactiver le  
mode PortFast sur les  
ports d'extrémité d'une  
liaison entre équipements

```
S1(config)# interface fa0/1
S1(config-if)# switchport mode access
S1(config-if)# spanning-tree portfast
%Warning: portfast should only be enabled on ports connected to a single
host. Connecting hubs, concentrators, switches, bridges, etc... to this
interface when portfast is enabled, can cause temporary bridging loops.
Use with CAUTION
%Portfast has been configured on FastEthernet0/1 but will only
have effect when the interface is in a non-trunking mode.
S1(config-if)# exit
S1(config)# spanning-tree portfast default
%Warning: this command enables portfast by default on all interfaces. You
should now disable portfast explicitly on switched ports leading to hubs,
switches and bridges as they may create temporary bridging loops.
S1(config)# exit
```



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 4- Attaque STP

## 4-c/ Alternative : (part2)

### Utilisation du mode BPDU Guard :

un port du commutateur peut recevoir des BPDU inattendus

- accidentellement
- un utilisateur a connecté un commutateur non autorisé

désactive immédiatement un port qui reçoit par erreur un BPDU

- le port recevant le BPDU est arrêté
- le port doit être réactivé manuellement (shutdown et no shutdown)

appliquer ce mode à **tous les ports reliant des utilisateurs feuilles**  
**ne pas appliquer sur les liaisons entre équipements (boucle)**

- (conf-if)#**spanning-tree bpduguard enable** active le mode
- (conf-if)#**spanning-tree bpduguard disable** désactive le mode
- (conf)#**spanning-tree portfast bpduguard default** sur toutes interfaces

```
Switch#sh spanning-tree summary
Switch is in pvst mode
Root bridge for:
Extended system ID      is enabled
Portfast Default        is enabled
PortFast BPDU Guard Default is enabled
Portfast BPDU Filter Default is disabled
Loopguard Default       is disabled
EtherChannel misconfig guard is disabled
UplinkFast              is disabled
BackboneFast            is disabled
Configured Pathcost method used is short
```

Mode portfast activé par défaut.  
pensez à le désactiver sur les ports d'extrémité  
des liaisons entre équipements

Mode BPDUGuard activé par défaut.  
pensez à le désactiver sur les ports d'extrémité  
des liaisons entre équipements

```
Switch#sh run | begin span
spanning-tree mode pvst
spanning-tree portfast default
spanning-tree portfast bpduguard default
spanning-tree extend system-id
```



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 4 - Attaque STP

### 4-d/ réactivation des ports :

lorsqu'une sécurité sur un port est transgressée : **err-disabled** au niveau de son fonctionnement le port est « shutdown »

```
switch# show interfaces FastEthernet0/1 status
Port      Name      Status      Vlan      Duplex  Speed  Type
Fa0/1     err-disabled  100        full      100     100BaseTX
```

réactivation manuelle du port : **shutdown / no shutdown**

réactivation automatique du port :

*remise en fonction d'un port mis en « errDisable »*

*définir la cause d'état errDisable concernée par la réactivation*

*définir l'intervalle à partir duquel le port est réactivé (en seconde)*

```
switch(config)# errdisable recovery interval 1800
switch(config)# errdisable recovery cause psecure-violation
switch(config)# errdisable recovery cause bpduguard
```

```
switch#sh errdisable recovery
ErrDisable Reason  Timer Status
-----
udld               Disabled
bpduguard          Enabled
psecure-violation  Enabled
Timer interval: 1800 seconds
```

*Toutes les 1800 secondes dans l'exemple, le commutateur réinitialise les ports dont l'état est « errDisable » pour les causes qui ont été définies.*

*Commandes ne permettant pas d'éviter la cause du problème mais permettant d'automatiser la remise en fonction automatique des ports.*

Interfaces that will be enabled at the next timeout:  
*liste des interfaces concernées par la réactivation + temps restant*

*Toutes les 30 minutes, les ports en « errDisable » pour causes liées au port-security ou bpduguard sont réactivés.*



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 5 - Attaque par SPAN/RSPAN

### 5-a/ Le principe : le mirroring

SPAN = Switched Port ANalyzer

obtenir un accès sur l'un des ports d'un commutateur

recopier le trafic d'un ou d'un ensemble de ports d'entrée

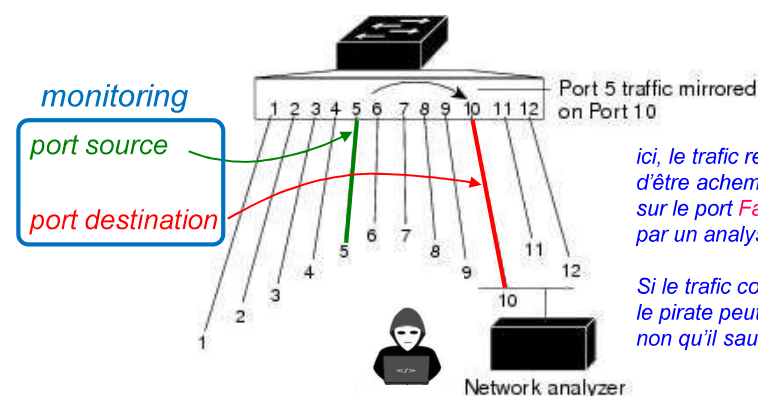
installation d'un sonde matérielle ou d'un logiciel de capture

on parle de port en miroir l'un de l'autre

### 5-b/ La conséquence :

observation de ce trafic sur un port de monitoring

**écoute** de l'entièreté du trafic passant par le commutateur



*ici, le trafic reçu sur le port Fa0/5, en plus d'être acheminé à sa destination, est recopié sur le port Fa0/10 et peut donc être écouté par un analyseur de réseau logiciel ou matériel*

*Si le trafic concerne des sessions de connexion, le pirate peut disposer des données cryptées ou non qu'il sauvegarde enfin d'investiguer ...*





## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 5 - Attaque par SPAN/RSPAN

## 5-c-1/ Le SPAN : configuration

envoi une copie des trames reçues et émises sur un port  
envoi sur un ou plusieurs ports du même commutateur

Définition de :

- le port source à analyser
- le port de destination en miroir
- flux port source à analyser (reçu *rx*, transmis *tx*, les deux *both*)

Commandes :

- (conf)#*monitor session 1 source interface Fa0/1 [rx|tx|both]*
- (conf)#*monitor session 1 destination interface Fa0/24*
- (conf)#*monitor session 1 filter vlan 1,2-4,99*

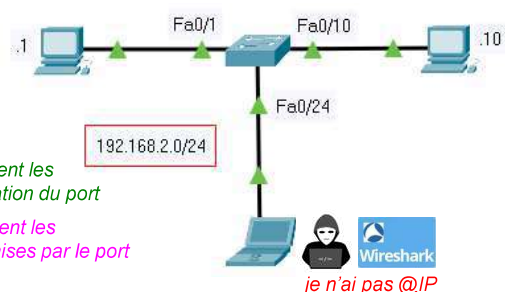
permet de ne considérer que le trafic venant et/ou sortant d'un certain nombre de VLAN parmi les hôtes connectés

```
(conf)#monitor session 1 source interface Fa0/1 , Fa0/10
(conf)#monitor session 1 source interface Fa0/20 rx
(conf)#monitor session 1 source interface Fa0/21 tx
(conf)#monitor session 1 destination interface Fa0/24
```

```
SWMirror#show monitor
Session 1
-----
Type          : Local Session
Description    : -
Source Ports   :
  RX Only      : Fa0/20
  TX Only      : Fa0/21
  Both         : Fa0/1, Fa0/10
Destination Ports : Fa0/24
Encapsulation : Native
Ingress       : Disabled
```

écoute uniquement les trames à destination du port

écoute uniquement les trames à transmises par le port



je n'ai pas @IP



## SÉANCE n°2



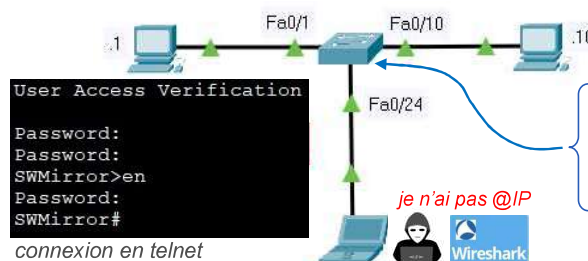
BUT R&T

Ressource R4.Cyber.09

# 5 - Attaque par SPAN/RSPAN

## 5-c-2/ Le SPAN : exemple

l'accès à distance au commutateur est possible  
mais l'adresse IP est inconnu et les restrictions d'accès aussi  
**avec du monitoring et un peu de patience ...**



```
User Access Verification
Password:
Password:
SWMirror>en
Password:
SWMirror#
```

connexion en telnet

@IP du commutateur  
@IP du client  
protocole de connexion



l'utilisateur entre le mot de passe de session telnet



l'utilisateur entre le mot de passe de du mode privilégié afin de vérifier la configuration suspecte du commutateur !

bizarre ce mirroring,  
je l'enlève donc !

interface vlanx  
ip address « inconnue »  
line vty 0 15  
password « inconnu »  
login  
enable password « inconnu »

```
SRC IP:192.168.2.200
DST IP:192.168.2.1
TELNET DATA : User Access Verification Password :
TELNET DATA : t
TELNET DATA : e
TELNET DATA : l
TELNET DATA : n
TELNET DATA : e
TELNET DATA : t
TELNET DATA : Password :
TELNET DATA : p
TELNET DATA : r
TELNET DATA : i
TELNET DATA : v
TELNET DATA : i
TELNET DATA : l
TELNET DATA : e
TELNET DATA : g
TELNET DATA : e
TELNET DATA : SWMirror#
```

réalisation d'un filtre d'observation du trafic

password



Merci, je peux me connecter sur l'équipement 192.168.2.200

password



Merci, je peux me connecter sur l'équipement 192.168.2.200 et le configurer plus tard !  
le sommeil est réparateur ...





## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 5 - Attaque par SPAN/RSPAN

### 5-d-1/ Le RSPAN : configuration

envoi une copie des trames reçues et émises sur un port écoute sur un autre commutateur que celui espionné  
transmission à travers un Vlan spécifique

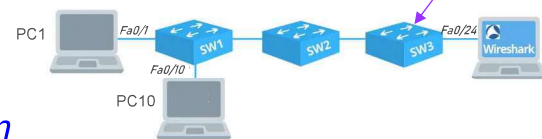
Définition de :

- le Vlan spécifique RSPAN sur tous les commutateurs
- le ou les ports sources à analyser
- le Vlan RSPAN de destination sur le **SWsource**
- le Vlan RSPAN de transition sur les commutateurs traversés
- le port destination en miroir du Vlan RSPAN sur **SWdestination**

Commandes :

- SWsource**
- (conf)#vlan 24
  - (conf-vlan)#remote-span
  - (conf)# monitor session 1 source interface Fa0/1 [rx|tx|both]
  - (conf)#monitor session 1 destination remote vlan 24 ...

- SWdestination**
- (conf)#vlan 24
  - (conf-vlan)#remote-span
  - (conf)# monitor session 1 source remote vlan 24
  - (conf)#monitor session 1 destination interface Fa0/24



... = reflector-port Fa0/20 sur ancien modèle tel 2950 !  
permet de se passer de limitations matérielles empêchant de répliquer le trafic vers le vlan RSPAN. Le port désigné est indisponible pour tout type de trafic (port non utilisé) et doit être affecté au Vlan remote.



## SÉANCE n°2



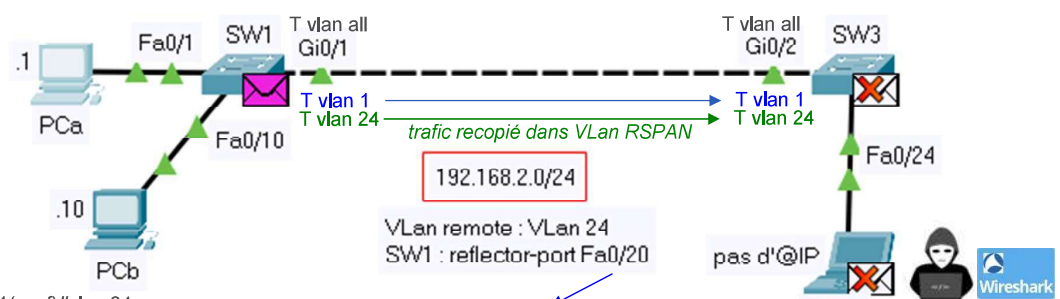
BUT R&T

Ressource R4.Cyber.09

## 5 - Attaque par SPAN/RSPAN

### 5-d-2/ Le RSPAN : exemple deux SW2950

l'accès à distance aux commutateurs est possible  
le lien entre les commutateurs autorise tous les Vlan (défaut)  
tous les équipements d'extrémité sont sur le Vlan par défaut  
**écoute du trafic des deux hôtes PCa et PCb à distance**



```
SW1(conf)#vlan 24
SW1(conf-vlan)#name RSPAN
SW1(conf-vlan)#remote-span
SW1(conf)#monitor session 1 source interface Fa0/1 , Fa0/10
SW1(conf)#monitor session 1 destination remote vlan 24 reflector-port Fa0/20
```

la création du Vlan24 n'est pas visible dans le #sh run  
le port Fa0/20 est en mode « shutdown » dans le #sh run

```
SW1#sh monitor session 1
Session 1
-----
Type                : Remote Destination Session
Description         : -
Source Ports        :
Both                : Fa0/1,Fa0/10
Dest RSPAN VLAN    : 24
```

```
SW3#sh monitor session 1
Session 1
-----
Type                : Remote Source Session
Description         : -
Source RSPAN VLAN   : 24
Destination Ports    : Fa0/24
Encapsulation       : Native
Ingress             : Disabled
```

```
SW3(conf)#vlan 24
SW3(conf-vlan)#name RSPAN
SW3(conf-vlan)#remote-span
SW3(conf)#monitor session 1 source remote vlan 24
SW3(conf)#monitor session 1 destination interface Fa0/24
```





## SÉANCE n°2



BUT R&T

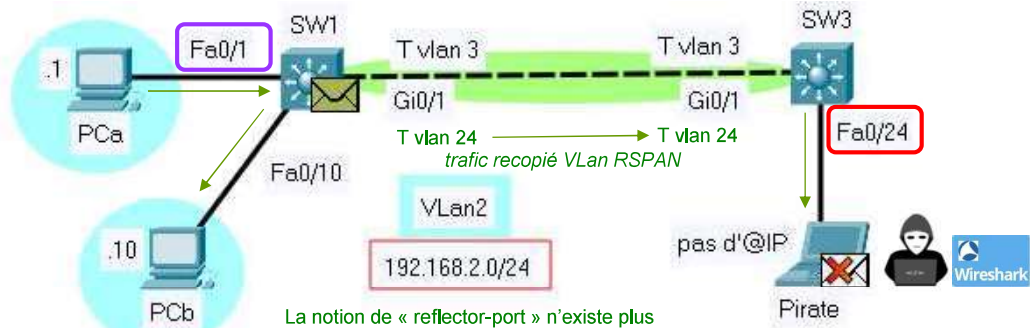
Ressource R4.Cyber.09

## 5 - Attaque par SPAN/RSPAN

### 5-d-3/ Le RSPAN : exemple deux SW3560

le lien entre les commutateurs autorise que les Vlan3 et 24  
les hôtes d'extrémité Pca et PCb sont sur le SW1-Vlan2

écoute du trafic du hôtes Pca à distance sur le SW3-Vlan1



```
SW1(conf)#interface range Fa0/1 - 10
SW1(conf-range)#switchport mode access
SW1(conf-range)#switchport access vlan 2
SW1(conf-range)#switchport nonegotiate
!
SW1(conf)#interface GigabitEthernet0/1
SW1(conf-if)#switchport trunk encapsulation dot1q
SW1(conf-if)#switchport mode trunk
SW1(conf-if)#switchport trunk allowed vlan 3,24
SW1(conf-if)#switchport nonegotiate
!
SW1(conf)#vlan 24
SW1(conf-vlan)#remote-span
SW1(conf)#monitor session 1 source interface Fa0/1
SW1(conf)#monitor session 1 destination remote vlan 24
```

Malgré un trafic restreint au Vlan2 sur le SW1, ne pouvant circuler sur le SW3 par les lien multiVLAN n'autorisant pas sa traversée aux trames du Vlan2, le « remote-span » achemine le trafic ciblé du port SW1-Fa0/1 vers le Pirate.

```
SW3(conf)#interface GigabitEthernet0/1
SW3(conf-if)#switchport trunk encapsulation dot1q
SW3(conf-if)#switchport mode trunk
SW3(conf-if)#switchport trunk allowed vlan 3,24
SW3(conf-if)#switchport nonegotiate
!
SW3(conf)#vlan 24
SW3(conf-vlan)#remote-span
SW3(conf)#monitor session 1 source remote vlan 24
SW3(conf)#monitor session 1 destination interface Fa0/24
```



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 5 - Attaque par SPAN/RSPAN

### 5-d-4/ Le RSPAN : exemple trois SW2950

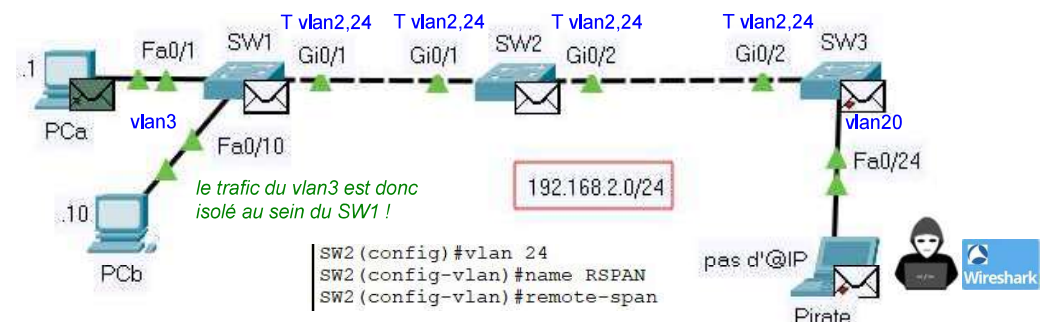
les deux hôtes sont sur des ports appartenant au Vlan3

le lien entre les commutateurs autorise que le Vlan2 et 24

tous les ports du SW2 sont sur le Vlan par défaut

le pirate est branché sur un port au hasard d'un Vlan20

écoute du trafic des deux hôtes Pca et PCb à distance



```
SW1(conf)#vlan 24
SW1(conf-vlan)#name RSPAN
SW1(conf-vlan)#remote-span
SW1(conf)#monitor session 1 source interface Fa0/1 , Fa0/10
SW1(conf)#monitor session 1 destination remote vlan 24 reflector-port Fa0/20
```

```
SW3(conf)#vlan 24
SW3(conf-vlan)#name RSPAN
SW3(conf-vlan)#remote-span
SW3(conf)#monitor session 1 source remote vlan 24
SW3(conf)#monitor session 1 destination interface Fa0/24
```

Le trafic de tout vlan, malgré les restrictions peut être écouté !  
du moment où le Vlan remote est propagé sur les commutateurs



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 5 - Attaque par SPAN/RSPAN

### 5-e-1/ Le RSPAN : exemple SW et routage

le LAN présente deux Vlan en plus de celui par défaut

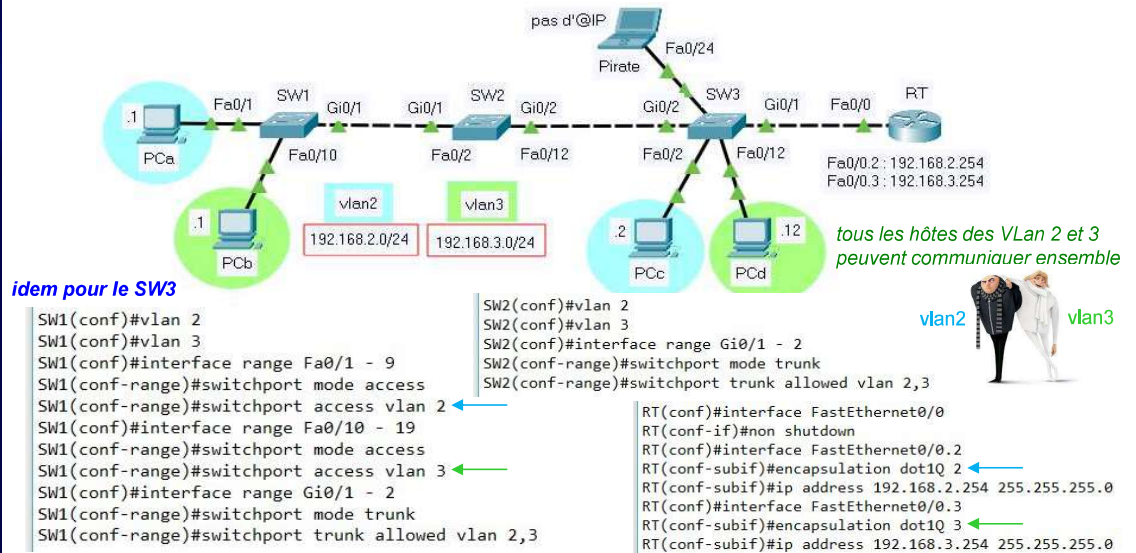
aucun hôte du réseau n'est placé sur le Vlan par défaut

les liens trunk sont limités aux Vlan 2 et 3

le routage n'est permis qu'entre les Vlan 2 et 3

le pirate est branché sur un port au hasard du Vlan par défaut

### Configuration d'origine pour le routage inter-Vlan



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 5 - Attaque par SPAN/RSPAN

### 5-e-2/ Le RSPAN : exemple SW et routage

création du Vlan24 « remote-span » sur les commutateurs

SW1 : recopie des trafics de PCa et PCb sur le Vlan24

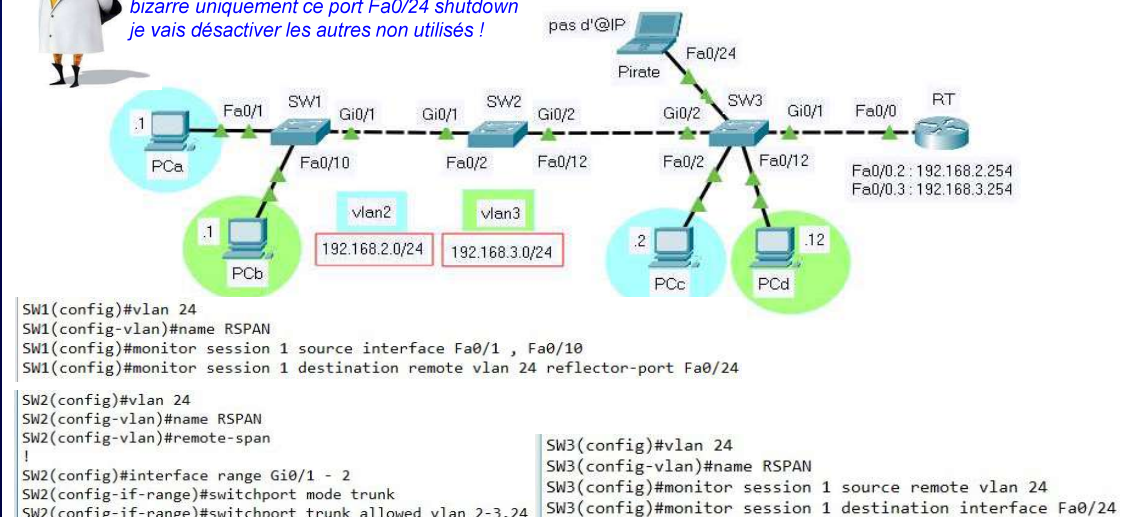
SW2 : recopie du trafic entre les deux ports Gi

SW3 : recopie du trafic du Vlan24 sur le port Fa0/24

### Configuration supplémentaire pour l'écoute

bizarre ce Vlan 24 mais pas de port associé  
donc, pas d'inquiétude !

bizarre uniquement ce port Fa0/24 shutdown  
je vais désactiver les autres non utilisés !







## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 6 – Sécurisation par VACL et PACL

## 6-a/ Limitations des RACL

Les listes de contrôle d'accès sont parfois appelés RACL  
*généralement placé au niveau des interfaces d'un routeur*  
*permettent de filtrer le trafic entre réseaux*  
*dans le cas de Vlan, permettent de filtrer le trafic entre Vlan*  
*ne permet pas de filtrer le trafic circulant au sein d'un Vlan*  
*les SW L2 supportent aussi bien les VACL que les PACL*

### Utilisation des VACL : Vlan Access Control List

*autoriser ou bloquer le trafic*  
*les listes de contrôle d'accès sont appliquées aux Vlan*  
*permettent d'autoriser ou non la propagation de trames dans un Vlan*  
*peuvent rediriger une trame vers une interface spécifique*  
*donc sont capables d'outrepasser le fonctionnement naturel du SW*

### Utilisation des PACL : Port Access Control List

*les listes de contrôle d'accès sont appliquées aux ports d'un SW*  
*peuvent filtrer selon les mêmes critères que les RACL*  
*supportent également du filtrage L2 selon les @MAC*  
*possèdent des limitations :*

- *syntaxe identique RACL en IPv4, nommée uniquement en @MAC*
- *ne filtre que le trafic entrant dans le port (ip access-group PACL in)*
- *ne filtre pas les protocoles de contrôle L2 (CDP, VTP, DTP, PagP, UDLD, STP)*
- *ne filtre pas les protocoles IPv6, ARP, MPLS*
- *n'est supporté que sur les matériels*
- *s'applique par la commande (conf-if)#ip access-group PACL in*



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 6 – Sécurisation par VACL et PACL

## 6-b-1/ Définition des VACL

### Méthode de création :

*définir les listes de contrôle d'accès de correspondance*  
*définir un Vlan access map composé d'une ou plusieurs séquences*  
*une séquence est composée d'un « match » et d'une « action »*  
*configurer la correspondance « match » en ip ou en mac address*  
*configurer la directive action réalisée pour la correspondance trouvée*  
*appliquer la VACL à un ou plusieurs Vlan*

### Exemple :

```
SW(conf)#ip access-list extended ICMP
SW(conf-ext-nacl)#permit icmp any any
SW(conf-ext-nacl)#exit
SW(conf)#ip access-list extended TELNET
SW(conf-ext-nacl)#permit ip tcp any any 23
SW(conf-ext-nacl)#exit
SW(conf)#ip access-list extended ALL
SW(conf-ext-nacl)#permit ip any any
SW(conf-ext-nacl)#exit
!
SW(conf)#vlan access-map VACL-EXEMPLE 10
SW(conf)#match ip address ICMP
SW(conf)#action drop
!
SW(conf)#vlan access-map VACL-EXEMPLE 20
SW(conf)#match ip address TELNET
SW(conf)#action drop log
!
SW(conf)#vlan access-map VACL-EXEMPLE 30
SW(conf)#match ip address ALL
SW(conf)#action forward
!
SW(conf)#vlan filter VACL-EXEMPLE vlan-list 20
```

*appliquer au Vlan20 une VACL*  
*interdit trafic ICMP et trafic Telnet*  
*autorise tout autre type de trafic*



*ensemble de listes contenant que des règles autorisées*  
*qui ne servent que de correspondance aux « access-map »*  
*qui les filtre par l'action « drop ».*

*liste ordonnée de règles avec règle implicite « drop »*  
*une VACL sans règle « forward » bloquera tout le trafic du/des Vlan*

**vlan access-map <name> <sequence>**  
**match {ip address {num\_acl | nom\_acl} | mac address nom\_acl}**  
**action forward | drop | redirect [log]**

*suit la logique de commutation du SW*      *trafic rejeté*      *redirection du trafic vers une interface spécifique outrepassant la logique SW*

**vlan filter nom\_vlan-access-map vlan-list num\_vlan**



## SÉANCE n°2



BUT R&T

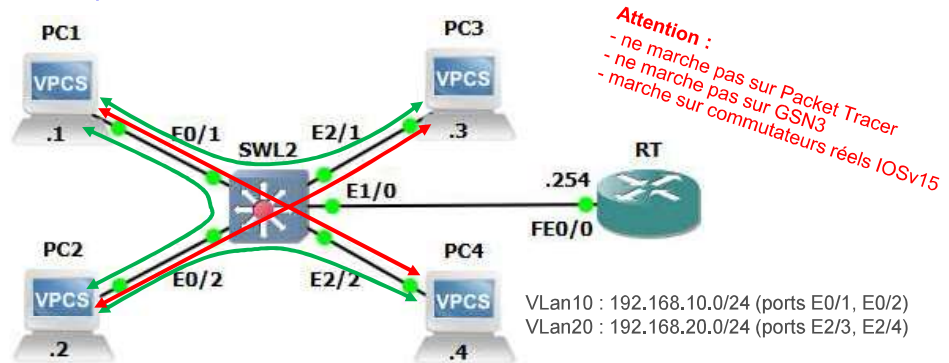
Ressource R4.Cyber.09

# 6 – Sécurisation par VACL et PACL

## 6-b-2/ Exemple de VACL

Cahier des charges :

- PC1 puisse communiquer uniquement avec le PC2 et PC3
- PC2 puisse communiquer uniquement avec le PC1 et PC4
- Tous les PC peuvent accéder à Internet



```
ip access-list extended ALL
permit icmp any any
!
ip access-list extended AUTORISE
permit icmp host 192.168.10.1 host 192.168.10.2
permit icmp host 192.168.10.1 host 192.168.20.3
permit icmp host 192.168.10.2 host 192.168.10.1
permit icmp host 192.168.10.2 host 192.168.20.4
!
ip access-list extended INTERDIT
permit icmp host 192.168.10.1 192.168.10.0 0.0.0.255
permit icmp host 192.168.10.1 192.168.20.0 0.0.0.255
!
```

```
vlan access-map VACL 10
match ip address AUTORISE
action forward
vlan access-map VACL 20
match ip address INTERDIT
action drop log
vlan access-map VACL 30
match ip address ALL
action forward
!
vlan filter VACL vlan-list 10
```



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 6 – Sécurisation par VACL et PACL

## 6-c/ les interactions entre types d'ACL

PACL, VACL et RACL sont appliqués dans le même VLAN

Ordre spécifique selon le trafic commuté ou trafic routé

Ordre de filtrage du trafic **commuté** au sein du même VLAN :

- 1 – PACL en entrée sur le port du commutateur
- 2 – VACL en entrée sur le VLAN affecté au port considéré
- 3 – VACL en sortie sur le VLAN d'appartenance du port considéré

Ordre de filtrage du trafic **routé** à travers des VLAN :

- 1 – PACL en entrée sur le port du commutateur
  - 2 – VACL en entrée sur le VLAN affecté au port considéré
  - 3 – RACL en entrée sur la sous-interface SVI VLAN A du routeur
  - 4 – RACL en sortie sur la sous-interface SVI VLAN B du routeur
  - 5 – VACL en sortie sur le VLAN B d'appartenance du port considéré
- et n'oublions pas que les PACL sortantes ne sont pas supportées ...**

## 6-d/ les autres types d'ACL

Downloadable : dACL

PACL pouvant être dynamiquement poussée par serveur d'authentification  
dACL écrase la PACL configurée si attribuée par le serveur RADIUS

MAC ACL :

ACL au niveau de l'@MAC  
utilisé comme PACL ou MACL

```
Router(config)# mac access-list extended mac_layer
Router(config-ext-macl)# deny 0000.4700.0001 0.0.0 0000.4700.0009 0.0.0
Router(config-ext-macl)# permit any any
```





## SÉANCE n°2



BUT R&T

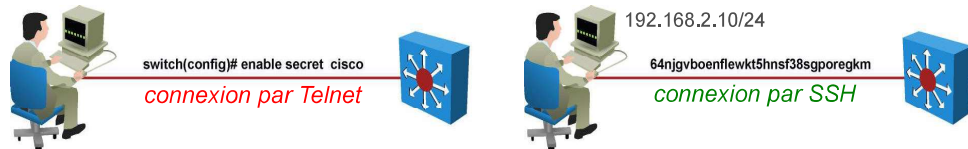
Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-a-1/ Limitations de Telnet :

### Vulnérabilités de Telnet :

*tous les identifiants, mots de passe et données sont transmis en clair*  
*possibilité d'ouvrir de multiples sessions pour une attaque DoS*  
*possibilité de découvrir puis usurper un compte sur une ressource*



### Alternative : utilisation de SSH

- définir un compte authentifié
- configurer un nom de machine/équipement et un nom de domaine
- générer un clé RSA d'au moins 2048 bits (**activation version 2**)
- ne permettre que la connexion SSH à distance
- limiter l'accès à un minimum de machines clientes (**ACL**)

```
Switch(config)#hostname SWhaut
SWhaut(config)#username Administr1TOR password 1a2b3c4d5!
SWhaut(config)#ip domain-name R&T.com
SWhaut(config)#crypto key generate rsa
The name for the keys will be: SWhaut.R&T.com
Choose the size of the key modulus in the range of 360 to
2048 for your General Purpose Keys. Choosing a key modulus
greater than 512 may take a few minutes.
How many bits in the modulus [512]: 1024 / 2048
% Generating 1024 bit RSA keys, keys will be non-exportable...[OK]
SWhaut(config)#ip ssh version 2
*Mar 1 0:3:31.811: %SSH-5-ENABLED: SSH 1.99 / 2 has been enabled
SWhaut(config)#line vty 0 15
SWhaut(config-line)#login local
SWhaut(config-line)#transport input ssh
```

```
SWhaut(config)#access-list 100 permit ip host 192.168.2.10 any
SWhaut(config)#line vty 0 15
SWhaut(config)#access-class 100 in
```

application d'un ACL  
limitant l'accès distant  
à une seule machine.

```
SWhaut>en
% No password set.
SWhaut>
```

ne pas oublier de définir  
le mot de passe d'accès  
au mode privilégié !

décryptage d'un  
mot de passe  
en quelques ms ...



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-a-2/ Limitations de HTTP :

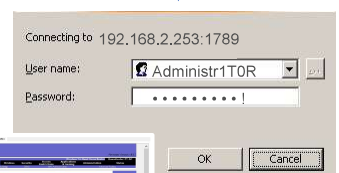
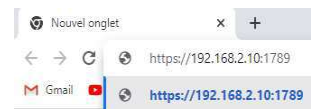
### Vulnérabilités de HTTP : date des années 1990

*protocole stable pendant près de 15 ans de v0.9 à v.2*  
*de multiples failles donnant lieu à des évolutions de versions*  
*ajout en 1994 de la couche sécuritaire (certificat) SSL de v1.0 à v3.1*  
*chiffrement afin de garantir l'authenticité/intégrité des messages*  
*SSL devient TLS de v1.0 à v1.3*

*utilisation d'un certificat contenant deux clés distinctes :*

- une clé publique validant le certificat racine
- une clé privée pour le chiffrement des échanges

```
SWhaut(config)#no ip http server désactivation de http
SWhaut(config)#ip http secure-server
SWhaut(config)#ip http secure-port 1789 (443 par défaut)
!
SWhaut(config)#username Administr1TOR password 1a2b3c4d5!
SWhaut(config)#ip http authentication local
SWhaut(config)#ip http secure-client-auth
!
SWhaut(config)#access-list 100 permit ip host 192.168.2.10 any
SWhaut(config)#ip http access-class 100 in
!
SWhaut#sh ip http server secure status
HTTP secure server status: Enabled
HTTP secure server port: 1789
HTTP secure server ciphersuite: 3des-ede-cbc-sha des-cbc-sha rc4-128-md5
rc4-128-sha aes-128-cbc-sha aes-256-cbc-sha dhe-aes-128-cbc-sha
dhe-aes-256-cbc-sha
HTTP secure server client authentication: Enabled
HTTP secure server trustpoint:
HTTP secure server active session modules: ALL
```





## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# PAUSE ?



10 minutes  
au maximum !



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

## 7 – Sécurisation par authentification

### 7-b-1/ Utilisation de l'authentification AAA

Principe du AAA (Authentication Authorization Accounting)  
*cadre par lequel il est possible de configurer un contrôle d'accès  
ensemble de trois fonctions de sécurité indépendantes et cohérentes*

### 7-b-2/ AAA Authentication

Authentification sans autorisation et log : **oui**  
Autorisation et log sans authentification : **non**

Prouver qu'on est bien qui on prétend être !



*Identifiant/mot de passe, biométrie, questions/réponses, certificats ...  
garantit que le message provient bien de qui il déclare venir  
fournit la structure nécessaire pour une sécurité d'accès évolutive*

#### Local AAA authentication :

- utilisation d'une base de données locale pour l'authentification
- méthode stockant localement les identifiants et mots de passe
- base de données identique que celle requise dans la CLI
- méthode idéale pour de petits réseaux

#### Server-based AAA authentication

- utilisation d'une base de données externe
- base de données située sur un serveur RADIUS ou TACACS+
- base de données ACS pour un serveur Windows par exemple
- méthode appropriée si de multiples routeurs dans le réseau

*qui est l'utilisateur ?*





## SÉANCE n°2



BUT R&T  
Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-b-3/ AAA Authorization

### Gestion des droits des utilisateurs



quels sont les droits  
de l'utilisateur ?

intervient automatiquement après la phase d'authentification  
détermine opérations autorisées pour l'utilisateur une fois authentifié  
utilisateurs autorisé ou non à accéder aux ressources spécifiques  
utilisation d'un ensemble d'attributs décrivant les privilèges  
ces attributs sont comparés aux informations de la BdD AAA  
les restrictions de l'utilisateur en sont déduites

l'autorisation peut être unique ou pour chaque service sollicité  
l'autorisation sur une liste de comptes par utilisateur ou par groupe  
utilise les serveurs de sécurité RADIUS ou TACACS+

## 7-b-4/ AAA Accounting



quelles actions l'utilisateur  
a-t-il effectué ?

### Traçage des connexions

logs qui rassemble et trie les données d'utilisation (audit/facturation)  
trace de la façon dont les ressources du réseau sont utilisées  
concept semblable à celui d'une carte de crédit  
exemple de données :

- identifiant
- date et durée de connexion
- commandes exécutées par l'utilisateur (création, édition, suppression)
- statistiques d'utilisation (nombre de paquets et d'octets transmis)

Carte de crédit : indique qui peut l'utiliser,  
combien il est possible de dépenser par  
semaine et garde trace des derniers  
mouvements bancaires dans sa mémoire



## SÉANCE n°2



BUT R&T  
Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-c-1/ local AAA Authentication (part1)

### Configuration d'une authentification locale

aussi appelé authentification indépendante  
utilise les comptes authentifiés déclarés sur un routeur par exemple  
fournit une manière de configurer les sauvegardes d'authentification  
configuration en quatre étapes :

- création de la base locale
- permettre l'authentification AAA sur le routeur
- configurer les paramètres AAA sur le routeur
- si nécessaire, déboguer les configuration AAA

commande : *nom utilisé pour la liste des méthodes d'authentification activées lorsqu'un utilisateur se connecte*

**RT(conf)#aaa authentication login {default | list-name} method1 à 4**

*utilise les méthodes d'authentification listées comme liste par défaut lorsqu'un utilisateur se connecte*

| Method type Keywords    | Description (Liste des méthodes que AAA interrogera dans la séquence donnée)                                                                               |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>enable</b>           | Uses the enable password for authentication.                                                                                                               |
| <b>krb5</b>             | Uses Kerberos 5 for authentication.                                                                                                                        |
| <b>krb5-telnet</b>      | Uses Kerberos 5 telnet authentication protocol when using telnet to connect to the router.                                                                 |
| <b>line</b>             | Uses the line password for authentication.                                                                                                                 |
| <b>local</b>            | Uses the local username database for authentication.                                                                                                       |
| <b>local-case</b>       | Uses case-sensitive local username authentication.                                                                                                         |
| <b>none</b>             | Uses no authentication.                                                                                                                                    |
| <b>cache group-name</b> | Uses a cache server group for authentication.                                                                                                              |
| <b>group radius</b>     | Uses the list of all RADIUS servers for authentication.                                                                                                    |
| <b>group tacacs+</b>    | Uses the list of all TACACS+ servers for authentication.                                                                                                   |
| <b>group group-name</b> | Uses a subset of RADIUS or TACACS+ servers for authentication as defined by the <b>aaa group server radius</b> or <b>aaa group server tacacs+</b> command. |



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-c-1/ local AAA Authentication (part2)

### Exemple d'une authentification locale

```
Router(config)#hostname RT
RT(config)#enable secret privilege
!
RT(config)#no ip domain-lookup
RT(config)#ip domain-name RT.com
RT(config)#crypto key generate rsa
The name for the keys will be: SWhaut.RT.com
Choose the size of the key modulus in the range of 360 to
2048 for your General Purpose Keys. Choosing a key modulus
greater than 512 may take a few minutes.
How many bits in the modulus [512]: 2048
% Generating 2048 bit RSA keys, keys will be non-exportable...[OK]
SWhaut(config)#ip ssh version 2
*Mar 1 0:3:31.811: %SSH-5-ENABLED: SSH 2 has been enabled
!
RT(config)#username JUNIOR privilege 15 password 0 Str0ngJRPa55w0rd
RT(config)#username SENIOR privilege 15 password 0 Str0ngSRPa55w0rd
!
RT(config)#aaa new-model
RT(config)#aaa authentication login default local-case enable
RT(config)#aaa authentication login DISTANCE local-case
RT(config)#aaa local authentication attempts max-fail 3
RT(config)#line vty 0 4
RT(config-line)#exec-timeout 1 30
RT(config-line)#login authentication DISTANCE
RT(config-line)#transport input ssh
```

*Configuration de la connexion SSH avec une clé de 2048 bits permettant d'activer la version 2 plus sécurisée*

*Définition des comptes authentifiés*

*activation de l'authentification AAA par défaut si pas de base locale définie, authentification en connaissant le mot de passe « enable »*

*activation de l'authentification AAA de type « local-case »*

*nombre maximum d'essais avant verrouillage*

*déconnexion automatique après 1 minute 30 seconde d'inactivité*

*applique la liste des méthodes d'authentification définie dans DISTANCE*

*connexion distance uniquement en SSH*

```
RT# sh aaa sessions
Total sessions since last reload: 13
Session Id: 13
  Unique Id: 25
  User Name: JUNIOR
  IP Address: 192.168.2.10
  Idle Time: 0
  CT Call Handle: 0
RT#
```

*affiche les attributs pour les utilisateurs authentifiés avec sessions gérées par AAA*

*affiche la liste des utilisateurs verrouillés*

*déverrouille les utilisateurs verrouillés spécifiés*

*Efface les tentatives infructueuses déjà enregistrées pour les utilisateurs spécifiés*



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-c-2/ server-based AAA Authentication (part1)

### Deux protocoles prédominants sont utilisés :

*chacun possède des capacités et des fonctionnalités différentes le choix dépend des besoins de l'entreprise*

*TACACS+ : Terminal access control access control server plus protocole propriétaire Cisco*

*l'ensemble du paquet transmis est chiffré : sécurisation*

*offre des politiques d'autorisation par utilisateur / par groupe sépare l'authentification de l'autorisation*

*compatible avec les protocoles TACACS et XTACACS*

*utilise le port TCP 49 donc fiabilité par la couche transport*

|                    | TACACS+                 |
|--------------------|-------------------------|
| Functionality      | Separates AAA           |
| Transport Protocol | TCP                     |
| CHAP               | Bidirectional           |
| Protocol Support   | Multi-protocol support  |
| Confidentiality    | Entire Packet-Encrypted |
| Accounting         | Limited                 |

*RADIUS : Remote dial-in user services (RFC 2865-2866) protocole ouvert développé par Livingston Enterprise*

*mot de passe utilisateur seul est crypté (et le login avec TLS)*

*utilise le serveur proxy radius pour l'adaptabilité*

*associe authentification et autorisation comme un processus dispose de plus d'informations à disposition pour le traçage*

*compatible avec technologies d'accès distants 802.1x et SIP utilise le port UDP 1812 (authentication/authorization)*

*utilise le port UDP 1813 (accounting)*

*peut également utilisé les ports UDP 1645 et 1646*

|                    | RADIUS                                |
|--------------------|---------------------------------------|
| Functionality      | Combines Authentication Authorization |
| Transport Protocol | UDP                                   |
| CHAP               | Unidirectional                        |
| Protocol Support   | No ARA No NetBEUI                     |
| Confidentiality    | Password-Encrypted                    |
| Accounting         | Extensive                             |





## SÉANCE n°2



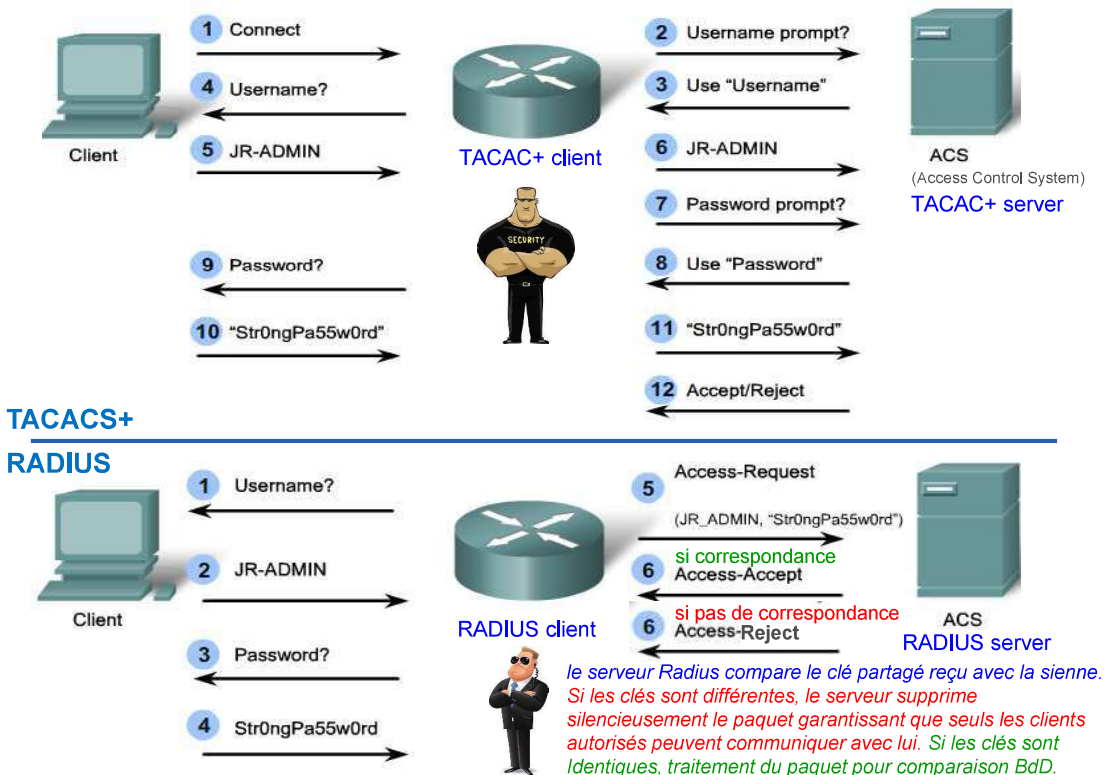
BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-c-2/ server-based AAA Authentication (part2)

Comparaison entre les deux protocoles :



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-c-2/ server-based AAA Authentication (part3)

Configuration de l'authentification distante :

*nécessité d'identifier le serveur TACACS+ ou RADIUS  
possibilité de configurer plusieurs serveurs pour la redondance*

configuration en quatre étapes :

- permettre l'authentification AAA sur le routeur
- spécifier le serveur TACACS+ ou RADIUS
- configurer clé de cryptage pour transfert de données avec serveur
- configurer le liste des méthodes AAA d'identification

lorsque les serveurs de sécurité sont identifiés :

- ils peuvent être inclus dans la liste des méthodes d'authentification
- serveur AAA identifié en utilisant la notion de group
- group tacacs+ ou group radius

**RT(conf)#aaa authentication login default group radius group tacacs+ local-case**

```

R1(config)# aaa authentication login default ?
enable          Use enable password for authentication.
group           Use Server-group
krb5            Use Kerberos 5 authentication.
krb5-telnet     Allow logins only if already authenticated via Kerberos V Telnet.
line           Use line password for authentication.
local          Use local username authentication.
local-case     Use case-sensitive local username authentication.
none           NO authentication.
passwd-expiry  enable the login list to provide password aging support

R1(config)# aaa authentication login default group ?
WORD           Server-group name
radius         Use list of all Radius hosts.
tacacs+        Use list of all Tacacs+ hosts.
  
```



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-c-2/ server-based AAA Authentication (part3)

### Configuration du client TACACS+ :

```
RT(config)#tacacs-server ?
administration Start tacacs+ daemon handling administrative messages
attribute Customize selected tacacs attributes
cache AAA auth cache default server group
directed-request Allow user to specify tacacs server to use with '@server'
dns-alias-lookup Enable IP Domain Name System Alias lookup for TACACS
servers
domain-stripping Strip the domain from the username
host Specify a TACACS server
key Set TACACS+ encryption key.
packet Modify TACACS+ packet options
timeout Time to wait for a TACACS server to reply

RT(config)#tacacs-server key ?
0 Specifies an UNENCRYPTED key will follow
7 Specifies HIDDEN key will follow
LINE The UNENCRYPTED (cleartext) shared key

RT(config)#tacacs-server host 192.168.2.100 ?
key per-server encryption key (overrides default)
nat To send client's post NAT address to tacacs+ server
port TCP port for TACACS+ server (default is 49)
single-connection Multiplex all packets over a single tcp connection to
server (for CiscoSecure)
timeout Time to wait for this TACACS server to reply (overrides
default)
<cr>

RT(config)#tacacs-server host 192.168.2.100 key ?
0 Specifies an UNENCRYPTED key will follow
7 Specifies HIDDEN key will follow
LINE The UNENCRYPTED (cleartext) shared key
```

*permet d'améliorer les performances TCP en maintenant une seule connexion TCP pour la durée de la session*

RT(conf)#tacacs-server host 192.168.2.100 single-connection key WinTACACS+



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-c-2/ server-based AAA Authentication (part4)

### Configuration du client RADIUS :

```
RT(config)#radius-server ?
accounting Accounting information configuration
attribute Customize selected radius attributes
authorization Authorization processing information
backoff Retry backoff pattern(Default is retransmits with
constant delay)
cache AAA auth cache default server group
challenge-noecho Data echoing to screen is disabled during
Access-Challenge
configure-nas Attempt to upload static routes and IP pools at startup
dead-criteria Set the criteria used to decide when a radius server is
marked dead
deadtime Time to stop using a server that doesn't respond
directed-request Allow user to specify radius server to use with '@server'
domain-stripping Strip the domain from the username
host Specify a RADIUS server
key encryption key shared with the radius servers
load-balance Radius load-balancing options.
optional-passwords The first RADIUS request can be made without requesting a
password
retransmit Specify the number of retries to active server
retry Specify how the next packet is sent after timeout.
source-ports source ports used for sending out RADIUS requests
throttle Throttle requests to radius server
timeout Time to wait for a RADIUS server to reply
transaction Specify per-transaction parameters
unique-ident Higher order bits of Acct-Session-Id
vsa Vendor specific attribute configuration

RT(config)#radius-server host 192.168.2.100 ?
acct-port UDP port for RADIUS accounting server (default is 1646)
alias 1-8 aliases for this server (max. 8)
auth-port UDP port for RADIUS authentication server (default is 1645)
backoff Retry backoff pattern (Default is retransmits with constant
delay)
key per-server encryption key (overrides default)
non-standard Parse attributes that violate the RADIUS standard
pac Generate per-server Protected Access Credential key
retransmit Specify the number of retries to active server (overrides
default)
test Configure server automated testing.
timeout Time to wait for this RADIUS server to reply (overrides
default)
<cr>

RT(config)#radius-server host 192.168.2.100 auth-port ?
<0-65535> Port number
RT(config)#radius-server host 192.168.2.100 acct-port ?
<0-65535> Port number

RT(config)#radius-server host 192.168.2.100 auth-port 1812 acct-port 1813 key ?
0 Specifies an UNENCRYPTED key will follow
7 Specifies HIDDEN key will follow
LINE The UNENCRYPTED (cleartext) server key
```

RT(conf)#radius-server host 192.168.2.100 auth-port 1812 acct-port 1813 key WinRADIUS





## SÉANCE n°2



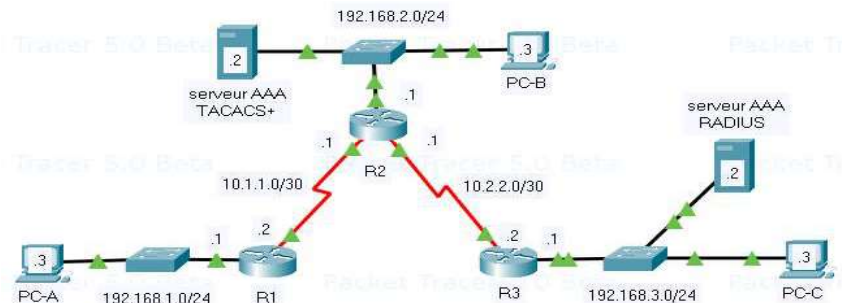
BUT R&T  
Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-d/ Application AAA local et serveurs (part1)

### Cahier des charges :

- configurer un compte utilisateur local sur R1 et s'authentifier sur la console et les lignes VTY en utilisant la base locale AAA
- vérifier l'authentification AAA locale via la console R1 et le client PC-A
- configurer sur R2 une authentification AAA sur serveur à l'aide de TACACS+
- vérifier l'authentification AAA sur serveur à partir du client PC-B
- configurer sur R3 une authentification AAA sur serveur à l'aide de RADIUS
- vérifier l'authentification AAA sur serveur à partir du client PC-C
- l'accès au mode privilégié nécessite le mot de passe : « **ciscoenpa55** »
- les comptes authentifiés respectifs sont : Adminx/adminxpa55 sur Rx
- la clé définie pour le serveur TACACS+ est : « **tacacspa55** »
- la clé définie pour le serveur RADIUS est : « **radiuspa55** »
- le routage utilisé sera le RIP version 2



## SÉANCE n°2

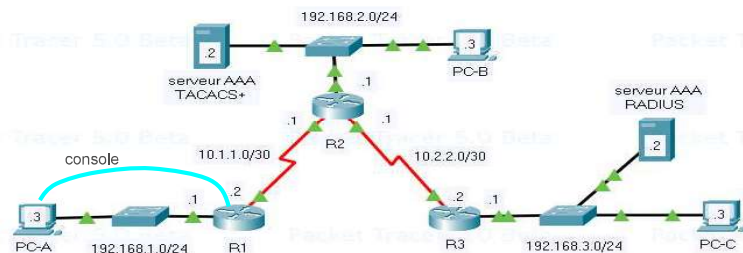


BUT R&T  
Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-d/ Application AAA local et serveurs (part2)

### Local AAA authentication sur R1 :



```
R1(conf)#hostname R1
R1(conf)#enable secret ciscoenpa55
R1(conf)#username Admin1 password 0 admin1pa55
!
R1(conf)#aaa new-model
R1(conf)#aaa authentication login default local
R1(conf)#aaa authentication login TELNET-LOGIN local
!
R1(conf)#interface FastEthernet0/0
R1(conf-if)#ip address 192.168.1.1 255.255.255.0
R1(conf-if)#no shutdown
R1(conf)#interface Serial0/0/0
R1(conf-if)#ip address 10.1.1.2 255.255.255.252
R1(conf-if)#clock rate 128000
R1(conf-if)#no shutdown
R1(conf)#router rip
R1(conf-router)#version 2
R1(conf-router)#network 10.0.0.0
R1(conf-router)#network 192.168.1.0
R1(conf-router)#no auto-summary
!
R1(conf)#logging trap debugging
R1(conf)#ntp update-calendar
R1(conf)#line con 0
R1(conf-line)#login authentication default
R1(conf)#line vty 0 4
R1(conf-line)#login authentication TELNET-LOGIN
```

activation de  
la méthode  
d'authentification  
locale

configuration  
des interfaces  
et du routage  
dynamique RIP

application de la méthode  
d'authentification sur la  
console et les lignes vty

Tests à partir du PC-A  
- accès par la console  
- accès par Telnet

```
User Access Verification

Username: Admin1
Password: admin1pa55
R1>en
Password: ciscoenpa55
R1#
```



# SÉANCE n°2



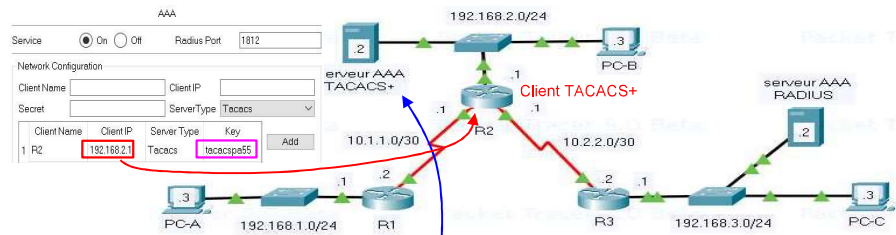
BUT R&T

Ressource R4.Cyber.09

## 7 – Sécurisation par authentification

### 7-d/ Application AAA local et serveurs (part3)

#### TACACS+ AAA authentication sur R2 :



```
Router(config)#hostname R2
R2(config)#enable secret ciscoenpa55
R2(config)#username Admin password 0 adminpa55
!
R2(config)#aaa new-model
R2(config)#aaa authentication login default groupe tacacs+ local
R2(config)#tacacs-server host 192.168.2.2
R2(config)#tacacs-server key tacacspa55
!
R1(config)#interface FastEthernet0/0
R1(config-if)#ip address 192.168.2.1 255.255.255.0
R1(config-if)#no shutdown
R2(config)#interface Serial0/0/0
R2(config-if)#ip address 10.1.1.1 255.255.255.252
R2(config-if)#no shutdown
R2(config)#interface Serial0/0/1
R2(config-if)#ip address 10.2.2.1 255.255.255.252
R2(config-if)#clock rate 128000
R2(config-if)#no shutdown
R2(config)#router rip
R2(config-router)#version 2
R2(config-router)#network 10.0.0.0
R2(config-router)#network 192.168.2.0
R2(config-router)#no auto-summary
!
R2(config)#logging trap debugging
R2(config)#ntp update-calendar
R2(config)#line con 0
R2(config-line)#login authentication default
```

Base de donnée locale si TACACS+ défaillant

activation de la méthode d'authentification sur le serveur TACACS+ et en cas de défaillance du serveur, en base locale

configuration des interfaces et du routage dynamique RIP

application de la méthode d'authentification sur la console et les lignes vty

Tests à partir du PC-B ou PC-A  
- accès par la console  
- accès par Telnet

```
User Access Verification

Username: Admin2
Password: admin2pa55
R2>en
Password: ciscoenpa55
R2#
```

ATTENTION : si l'authentification TACACS+ est négative, la méthode suivante n'est pas consultée !



# SÉANCE n°2



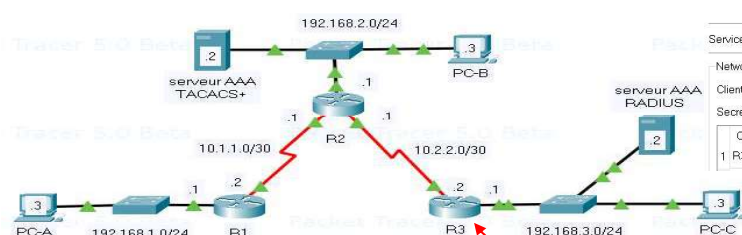
BUT R&T

Ressource R4.Cyber.09

## 7 – Sécurisation par authentification

### 7-d/ Application AAA local et serveurs (part4)

#### RADIUS AAA authentication sur R3 :



```
Router(config)#hostname R3
R3(config)#enable secret ciscoenpa55
R3(config)#username Admin password 0 adminpa55
!
R3(config)#aaa new-model
R3(config)#aaa authentication login default groupe radius local
R3(config)#radius-server host 192.168.3.2 auth-port 1645
R3(config)#radius-server key radiuspa55
!
R3(config)#interface FastEthernet0/1
R3(config-if)#ip address 192.168.3.1 255.255.255.0
R3(config-if)#no shutdown
R3(config)#interface Serial0/0/1
R3(config-if)#ip address 10.2.2.2 255.255.255.252
R3(config-if)#no shutdown
R3(config)#router rip
R3(config-router)#version 2
R3(config-router)#network 10.0.0.0
R3(config-router)#network 192.168.3.0
R3(config-router)#no auto-summary
!
R2(config)#logging trap debugging
R2(config)#ntp update-calendar
R2(config)#line con 0
R2(config-line)#login authentication default
```

Base de donnée locale si RADIUS défaillant

activation de la méthode d'authentification sur le serveur RADIUS et en cas de défaillance du serveur, en base locale

configuration des interfaces et du routage dynamique RIP

application de la méthode d'authentification sur la console et les lignes vty

Tests à partir du PC-C ou PC-A  
- accès par la console  
- accès par Telnet

```
User Access Verification

Username: Admin3
Password: admin3pa55
R3>en
Password: ciscoenpa55
R3#
```

ATTENTION : si l'authentification RADIUS est négative, la méthode suivante n'est pas consultée !





## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-d/ Application AAA local et serveurs (part5)

### Cas particulier sur un commutateur GSN3 : Tacacs+

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>SW1(config)#aaa ? accounting      Accounting configurations parameters. attribute       AAA attribute definitions authentication   Authentication configurations parameters. authorization    Authorization configurations parameters. cache           AAA cache definitions common-criteria AAA Common Criteria configuration    Authorization configuration parameters. dnis            Associate certain AAA para group           AAA group definitions local           AAA Local method options max-sessions     Adjust initial hash size f memory          AAA memory parameters nas             NAS specific configuration new-model       Enable NEW access control password        Configure password/secret pod            POD processing policy          AAA policy parameters server          Local AAA server service-profile  Service-Profile parameters session-id      AAA Session ID traceback       Traceback recording user            AAA user definitions</pre> | <pre>SW1(config)#aaa authentication login ACCESS ? cache          Use Cached-group enable         Use enable password for authentication. group          Use Server-group line           Use line password for authentication. local          Use local username authentication. local-case     Use case-sensitive local username authentication. none           NO authentication. passwd-expiry  enable the login list to provide password aging support</pre> |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

```
SW1(config)#enable secret ciscoenpa55
SW1(config)#username Admin password 0 adminpa55
SW1(config)#aaa new-model
!
SW1(config)#tacacs server TACACS+
SW1(config-server-tacacs)#address ipv4 192.168.2.2
SW1(config-server-tacacs)#key tacacspa55
SW1(config-server-tacacs)#port 49
SW1(config-server-tacacs)#single-connection
SW1(config-server-tacacs)#timeout 60
!
SW1(config)#tacacs server TACACS2+
SW1(config-server-tacacs)#address ipv4 192.168.2.22
SW1(config-server-tacacs)#key tacacs2pa55
SW1(config-server-tacacs)#port 49
SW1(config-server-tacacs)#single-connection
SW1(config-server-tacacs)#timeout 60
!
SW1(config)#aaa group server tacacs+ TACACS_ALL
SW1(config-sg-tacacs+)#server name TACACS+
SW1(config-sg-tacacs+)#server name TACACS2+
!
SW1(config)#aaa authentication login ACCESS group TACACS_ALL local
SW1(config)#line vty 0 15
SW1(config-line)#login authentication ACCESS
```

*pour l'authentification locale*

*serveur Tacacs+ principal*

*serveur Tacacs+ secondaire*

~~SW1(conf)#tacacs-server host 192.168.2.2~~  
~~SW1(conf)#tacacs-server key tacacspa55~~

**SW1(config)#aaa authentication login default group tacacs+ local**

|                                                                                                                                                                                                                    |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>SW1(config)#aaa authentication login default group ? WORD      Server-group name ldap      Use list of all LDAP hosts. radius    Use list of all Radius hosts. tacacs+   Use list of all Tacacs+ hosts.</pre> |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-d/ Application AAA local et serveurs (part5)

### Cas particulier sur un commutateur GSN3 : Radius

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>SW1(config)#aaa ? accounting      Accounting configurations parameters. attribute       AAA attribute definitions authentication   Authentication configurations parameters. authorization    Authorization configurations parameters. cache           AAA cache definitions common-criteria AAA Common Criteria configuration    Authorization configuration parameters. dnis            Associate cert group           AAA group defi local           AAA Local meth max-sessions     Adjust initial memory          AAA memory par nas             NAS specific c new-model       Enable NEW acc password        Configure pass pod            POD processing policy          AAA policy par server          Local AAA serv service-profile  Service-Profil session-id      AAA Session ID traceback       Traceback reco user            AAA user defin</pre> | <pre>SW1(config)#aaa authentication login ACCESS ? cache          Use Cached-group enable         Use enable password for authentication. group          Use Server-group line           Use line password for authentication. local          Use local username authentication. local-case     Use case-sensitive local username authentication. none           NO authentication. passwd-expiry  enable the login list to provide password aging support</pre> |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

```
SW1(config)#enable secret ciscoenpa55
SW1(config)#username Admin password 0 adminpa55
SW1(config)#aaa new-model
!
SW1(config)#tacacs server RADIUS
SW1(config-radius-server)#address ipv4 192.168.3.2 auth-port 1812 acct-port 1813
SW1(config-radius-server)#key radiuspa55
SW1(config-radius-server)#retransmit 5
SW1(config-radius-server)#timeout 60
!
SW1(config)#tacacs server RADIUS2
SW1(config-radius-server)#address ipv4 192.168.3.22 auth-port 1812 acct-port 1813
SW1(config-radius-server)#key radius2pa55
SW1(config-radius-server)#retransmit 5
SW1(config-radius-server)#timeout 60
!
SW1(config)#aaa group server radius RADIUS_ALL
SW1(config-sg-radius)#server name RADIUS
SW1(config-sg-radius)#server name RADIUS2
!
SW1(config)#aaa authentication login ACCESS group RADIUS_ALL local
SW1(config)#line vty 0 15
SW1(config-line)#login authentication ACCESS
```

*pour l'authentification locale*

*serveur Radius principal*

*serveur Radius secondaire*

~~R3(conf)#radius server host 192.168.3.2 auth-port 1645~~  
~~R3(conf)#radius server key radiuspa55~~

**SW1(config)#aaa authentication login default group radius local**

*auth-port : UDP 1645 par défaut*  
*acct-port : UDP 1646 par défaut*



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-e/ AAA Authorization (part1)

### Gestion des droits des utilisateurs

contrôle les actions et les commandes permises pour un utilisateur  
se configure selon le même principe de l'authentification :

- définir une liste de méthodes d'autorisation
- appliquer la liste à une ou plusieurs interfaces (sauf celle par défaut)
- les méthodes sont appliquées dans l'ordre de la liste (si non réponse)
- si aucune méthode d'autorisation ne fonctionne : message d'erreur

### Configuration

Soit une authentification basée sur un serveur Radius puis en local  
**SW(conf)#aaa authentication login default group radius local**

le serveur AAA utilise des attributs spécifiques pour les utilisateurs

- certaines commandes telles les #show sont disponible en mode « exec »
- les configurations ne sont possibles qu'en mode « config-commands »

permet d'utiliser toutes les commandes du SW pour tous les privilèges  
permet d'utiliser toutes les commandes de configuration  
permet d'entrer dans le mode de configuration du SW  
le serveur doit envoyer l'autorisation pour l'utilisateur d'exécuter une session avec un niveau de privilège, d'utiliser les services liés au réseau ou à Telnet

{commands | config-commands | configuration | exec | network | reverse-access}

**SW(conf)#aaa authorization {type\_autorisation} {default | nom-liste}**

liste-méthodes

group {radius | tacacs} : requêtes envoyées au serveur

If-authenticated : demandes accordées si l'utilisateur est authentifié

none : aucune autorisation externe n'est utilisée, autorisation avec succès

possibilité d'identifier la méthode avec un nom descriptif pour son application.



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-e/ AAA Authorization (part2)

### Configuration

TACACS+ permet d'accéder à des commandes spécifiques alors que les serveurs RADIUS sont plus dans une stratégie de « tout ou rien »

possibilité d'appliquer une liste de méthodes d'autorisation à un accès particulier sur le commutateur. Le groupe par défaut est utilisé pour tous les accès si pas de configuration spécifique

**SW(conf)#aaa authorization exec default group ACCESS none**

**SW(conf)#line type\_line numéro\_line**

**SW(conf-line)#authorization exec ACCESS**

SW1(config)#aaa authorization ?

|                     |                                                             |
|---------------------|-------------------------------------------------------------|
| auth-proxy          | For Authentication Proxy Services                           |
| cache               | For AAA cache configuration                                 |
| commands            | For exec (shell) commands.                                  |
| config-commands     | For configuration mode commands.                            |
| configuration       | For downloading configurations from AAA server              |
| console             | For enabling console authorization                          |
| credential-download | For downloading EAP credential from Local/RADIUS/LDAP       |
| exec                | For starting an exec (shell).                               |
| multicast           | For downloading Multicast configurations from an AAA server |
| network             | For network services. (PPP, SLIP, ARAP)                     |
| onep                | For ONEP authorization service                              |
| policy-if           | For diameter policy interface application.                  |
| prepaid             | For diameter prepaid services.                              |
| radius-proxy        | For proxying radius packets                                 |
| reverse-access      | For reverse access connections                              |
| subscriber-service  | For iEdge subscriber services (VPDN etc)                    |
| template            | Enable template authorization                               |

SW1(config)#aaa authorization commands ?

|              |                                                                              |
|--------------|------------------------------------------------------------------------------|
| <0-15>       | Enable level                                                                 |
| visible-keys | Send complete command to aaa server without masking off sensitive parameters |

SW1(config-line)#authorization ?

|                |                                      |
|----------------|--------------------------------------|
| arap           | For Appletalk Remote Access Protocol |
| commands       | For exec (shell) commands            |
| exec           | For starting an exec (shell)         |
| reverse-access | For reverse telnet connections       |

SW1(config-line)#authorization exec ?  
WORD Use an authorization list with this name  
default Use the default authorization list





## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-f/ AAA Accounting (part1)

### Traçage des connexions

traçage des connexions afin de suivre les services utilisés  
statistiques concernant les ressources réseaux utilisées  
informations pouvant être collectées par un serveur Tacacs+/Radius  
serveur déjà configuré et regroupé dans le cadre de l'authentification

### Configuration

utilise les mêmes principes et étapes de configuration AAA

- 1- définir une liste de méthodes comptables
- 2- appliquer la liste à une ou plusieurs interfaces (sauf défaut)
- 3- utilisation des méthodes dans l'ordre de déclaration

principaux événements de commutation tels un reload sont enregistrés

l'authentification de l'utilisateur dans une session EXEC est enregistrée avec adresse et la durée de session.

informations sur toutes les commandes de niveau voulu enregistrées avec l'utilisateur qui a émis la commande.

{system | exec | commands level}

```
SW(conf)#aaa accounting {accounting-type} {default | nom_liste}
{start-stop | stop only | none} method-list
```

enregistrements spécifiques :

- lorsqu'ils démarrent et s'arrêtent
- uniquement lorsqu'ils s'arrêtent
- aucun enregistrement d'évènement

```
SW(conf)#interface type_interface numéro_interface
```

```
SW(conf-if)#aaa accounting nom_liste
```

```
SW(conf-line)#aaa accounting {commands level | connection | exec} {default | nom_liste}
```

possibilité d'appliquer un traçage à une connexion console ou à distance.



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-f/ AAA Accounting (part2)

```
SW1(config)#aaa accounting ?
auth-proxy      For authentication proxy events.
commands        For exec (shell) commands.
connection       For outbound connections. (telnet, rlogin)
delay-start      Delay PPP Network start record until peer IP address is
                  known.
dot1x            For dot1x sessions.
exec             For starting an exec (shell).
gigawords        64 bit interface counters to support Radius attributes 52 &
                  53.
identity         For identity sessions.
include          Include attributes in accounting records unconditionally
jitter           Set jitter parameters for periodic interval
multicast        For multicast accounting.
nested           When starting PPP from EXEC, generate NETWORK records
                  before EXEC-STOP record.
network          For network services. (PPP, SLIP, ARAP)
onep             For ONEP events.
redundancy       AAA platform redundancy accounting behavior
send             Send records to accounting server.
session-duration Set the preference for calculating session durations
suppress         Do not generate accounting records for a specific type of
                  user.
system          For system events.
update           Enable accounting update records.
vrrs            For VRRS accounting.
```

SW1(config)#aaa accounting exec ?  
WORD Named Accounting list (max 31 characters, longer will be rejected).  
default The default accounting list.

SW1(config)#aaa accounting exec default ?  
none No accounting.  
start-stop Record start and stop without waiting  
stop-only Record stop when service terminates.  
<cr>

SW1(config)#aaa accounting exec default start-stop ?  
broadcast Use Broadcast for Accounting  
group Use Server-group

SW1(config)#aaa accounting exec default start-stop group

SW1(config)#aaa accounting exec default start-stop group  
WORD Server-group name  
radius Use list of all Radius hosts.  
tacacs+ Use list of all Tacacs+ hosts.

SW1(config)#aaa accounting commands ?  
<0-15> Enable level  
visible-keys Send complete command to aaa server without masking off  
sensitive parameters

SW1(config)#aaa accounting commands 15 default ?  
none No accounting.  
start-stop Record start and stop without waiting  
stop-only Record stop when service terminates.  
<cr>



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-g-1/ Authentification par port 802.1x

Principe de l'authentification : Port-based authentication  
*combinaison entre authentification AAA et sécurisation des ports*  
*le port ne laisse passer le trafic que lorsque l'utilisateur est connu*  
*commutateur et ordinateur du client final doivent supporter 802.1x*  
*utilise le protocole EAPOL (extensible authentication protocole over LAN)*

### Principe de EAPOL :

*protocole de niveau 2*

*si 802.1x activé le port reste dans l'état non autorisé par défaut*

*l'hôte ne peut donc pas communiquer avec autre chose que EAPOL*

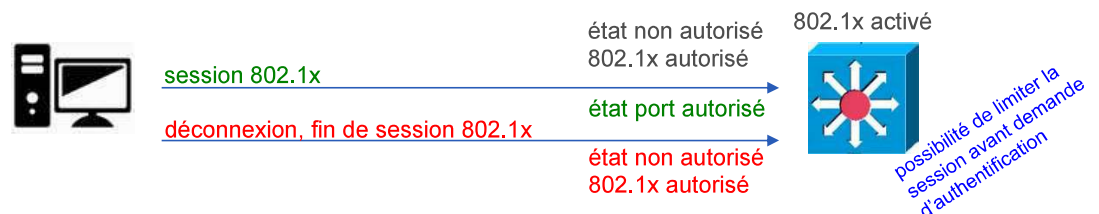
*l'hôte n'a pas conscience de la présence du commutateur*

*l'hôte ne peut récupérer des paramètres IP s'il est en mode DHCP*

*l'hôte doit obligatoirement implémenté une application cliente 802.1x*

*si l'hôte prend en charge 802.1x et switch non : abandon de 802.1x*

*si switch prend en charge 802.1x et hôte non : port non autorisé*



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

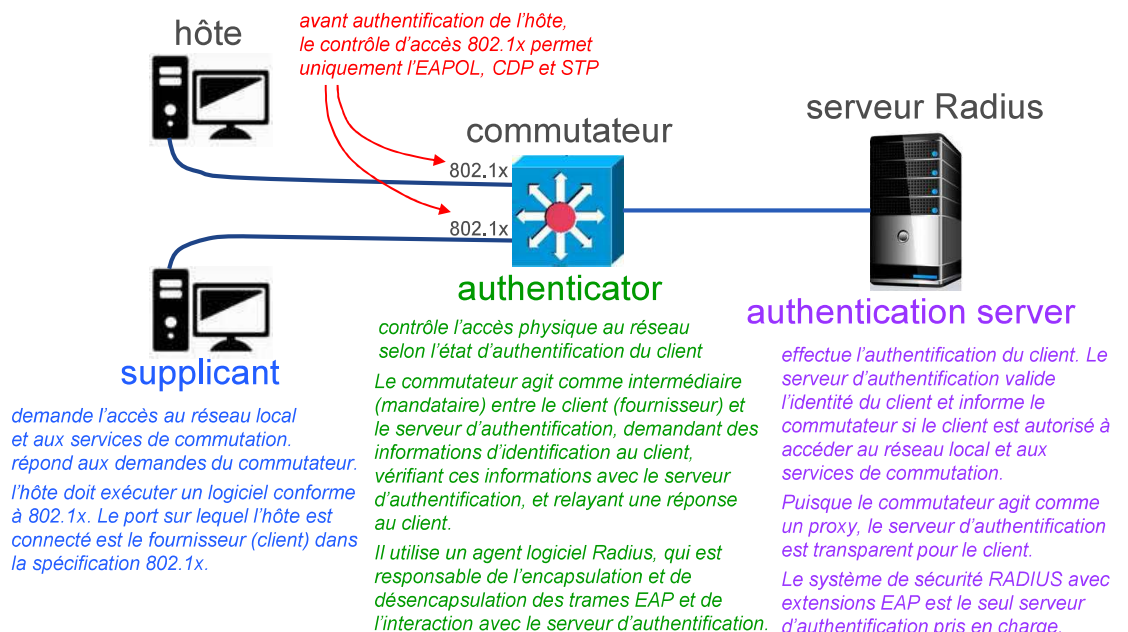
## 7-g-2/ Jargon utilisé

Rôle des différents acteurs :

*postes clients = supplicants*

*commutateur = authentificateur*

*server Radius = serveur d'authentification*







## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

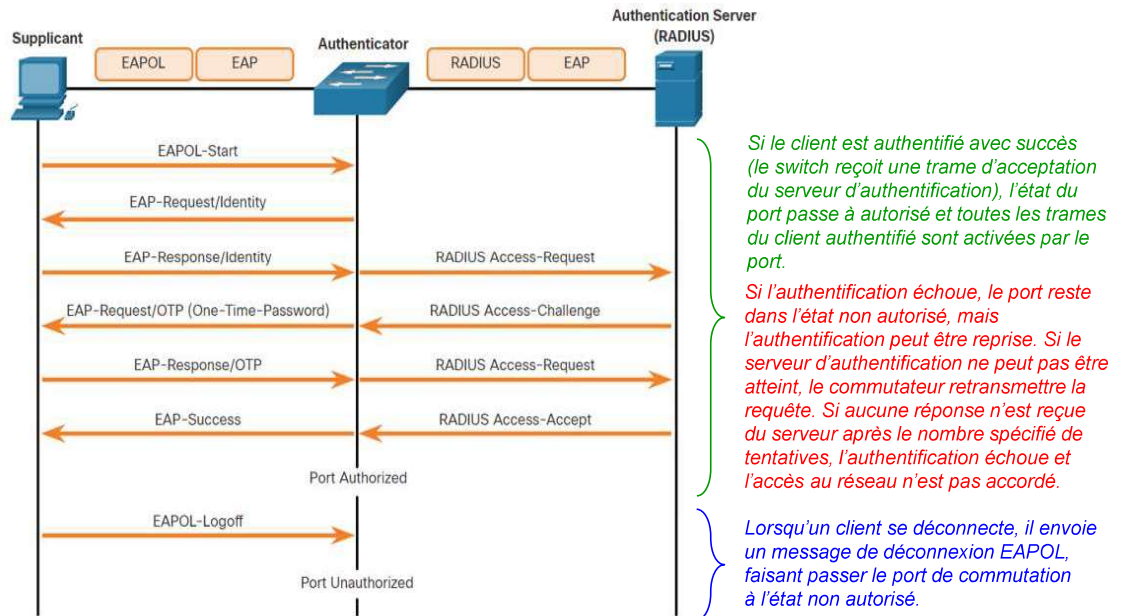
# 7 – Sécurisation par authentification

## 7-g-3/ Etude d'un échange 802.1x

Messages transmis entre les différents acteurs :

*supplicant-authenticator* : données EAP encapsulées dans trames EAPOL

*authenticateur-server* : données EAP encapsulées par Radius



## SÉANCE n°2



BUT R&T

Ressource R4.Cyber.09

# 7 – Sécurisation par authentification

## 7-g-4/ Configuration 802.1x (part1)

Méthode de configuration :

*authentification nécessitant le recours à un serveur Radius*

*méthode d'authentification Radius à configurer au préalable*

*la configuration 802.1x est à effectuer suivant les étapes :*

1- activer AAA sur le commutateur : `Switch(config)# aaa new-model`

2- définir les serveurs Radius externes :

`Switch(config)# radius-server host { hostname | ip-address } [ key string ]`

3- définir la méthode d'authentification :

`Switch(config)# aaa authentication dot1x default group radius`

4- activer 802.1x sur le commutateur : `Switch(config)# dot1x system-auth-control`

5- configurer chaque port concerné par l'authentification 802.1x :

`Switch(config-if)# authentication port-control { force-authorized | force-unauthorized | auto }`

```

Switch(config-if)# authentication port-control ?
auto          PortState set to automatic
force-authorized PortState set to AUTHORIZED <--default
force-unauthorized PortState set to Unauthorized
  
```

le port est forcé afin d'autoriser toutes les connexions des host. Aucune authentification n'est nécessaire. Il s'agit de l'état par défaut de tous les ports lorsque 802.1x est activé.

le port est forcé afin d'interdire toutes les connexions des host. Ainsi, le port ne pourra pas passer à l'état « autorisé » afin de laisser passer du trafic. Il laisse uniquement passer : EAPOL, CDP et STP.

le port utilise l'échange 802.1x afin d'autoriser ou non le trafic de données. Ceci nécessite une authentification du host.

6- activer authentification EAPOL sur le port : `Switch(config-if)# dot1x pae authenticator`

7- autoriser plusieurs hôtes sur un port du commutateur (éventuellement) :

`Switch(config-if)# dot1x host-mode multi-host`

802.1x peut prendre en compte le cas où plusieurs hôtes sont connectés au même port d'un commutateur à travers un autre équipement.



# SÉANCE n°2



BUT R&T

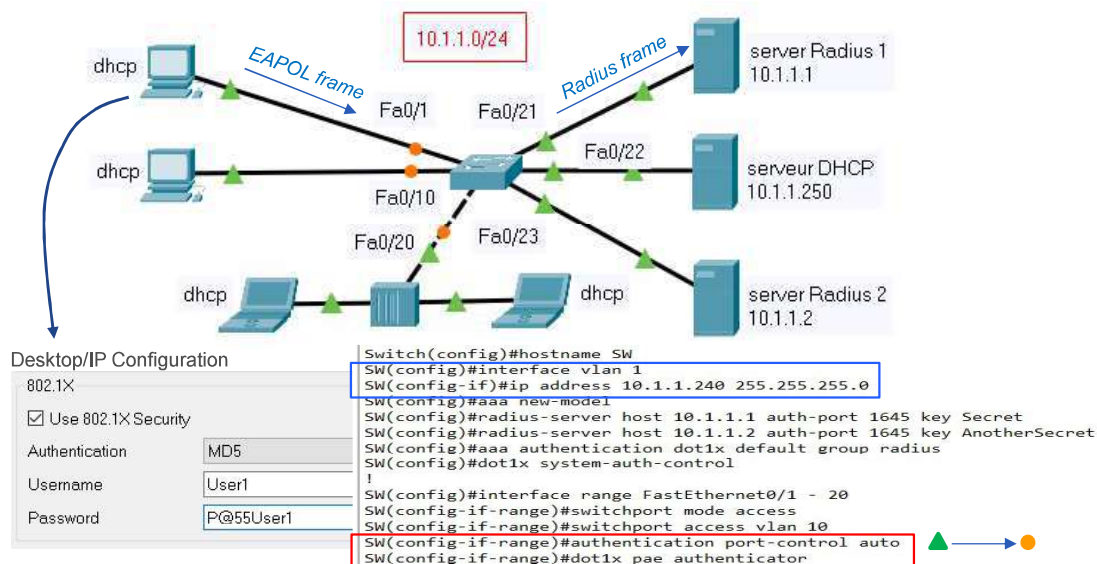
Ressource R4.Cyber.09

## 7 – Sécurisation par authentification

### 7-g-4/ Configuration 802.1x (part2)

#### Exemple de configuration :

deux serveurs radius sont disponibles aux adresses 10.1.1.1/2  
clés pour serveur1 : Secret et pour le serveur2 : AnotherSecret  
comptes clients : User1/P@55User1 et User2/P@55User2  
ports 1 à 20 du commutateur utilise une authentification par port  
lorsqu'authentifiés, les utilisateurs sont associés au Vlan 10



## Bachelor Universitaire de Technologie Réseaux & Télécommunications

Code ressource : **R4.Cyber.09**  
sécurité dans les LAN

### PARTIE I

**Sommaire :**  
Introduction  
**PARTIE I : 3 heures de cours magistraux**

1. Attaque de table d'adresses Mac  
Principe et conséquences du *Mac flooding* (inondation)  
Alternative par la sécurisation des ports des commutateurs (port security)  
Alternative par la création de VLANs de confiance (VLANs)
2. Attaque par et dans un VLAN  
Principe et conséquences du *Switch spoofing* et *VLAN hopping*  
Alternative par la désactivation du protocole CDP et configuration des ports  
Alternative par une configuration restrictive du VLAN (VLAN private VLAN)
3. Attaque par usurpation d'identité IP ou Mac  
Conséquences du *DHCP spoofing* (usurpation) et *DHCP starvation* (saturation)  
Alternative par la surveillance des requêtes DHCP (DHCP snooping)  
Alternative par l'inspection des adresses IP associées aux ports (IP source Guard)  
Alternative par l'inspection des requêtes ARP (Dynamic ARP inspection)

THE END



### PARTIE II

**Sommaire :**  
**PARTIE II : 3 heures de cours magistraux**

4. Attaque par STP  
Conséquences du *Root spoofing* (usurpation) et du *DoS de BPDU*  
Alternative par les modes « PortFast » et « BPDU Guard »
5. Attaque par SPAN/RSPAN  
Principe et conséquences du *Monitoring* (espionnage)  
Alternative par la sécurisation des ports des commutateurs (port security)
6. Sécurisation par utilisation des VACL/PACL  
Limitation des RACL (ACL au niveau des interfaces des routeurs)  
Principe de fonctionnement des VACL et transitions RACL/VACL/PACL
7. Sécurisation par authentification 802.1x  
Limitation de l'accès et l'usage : utilisation de SSH et de HTTPS  
Principe de l'architecture AAA (Authentification, Autorisation, Accounting)  
Principe et configuration d'un serveur Radius  
Principe et configuration d'un serveur TACACS+

Coefficient : 10/300 (UE44 : 8 – UE45 : 2)

Heures encadrées : 13 heures dont 6h de TP

CM : 6h – TP : 6h – DS : 1h

Deux notes : **TP1** + **TP2** (coef.1) + **DS** (coef.1)





# SÉANCE TP



BUT R&T

Ressource R4.Cyber.09

## Exemple travaux pratiques ?

- fil directeur et progression
- complétude et difficulté
- accompagnement, justification
- exercice synthèse/solution
- qualité rédactionnelle

### TP1 ?

*présentation du contexte des attaques*  
*mise en œuvre du port-security*  
*mise en œuvre du storm control*  
*mise en œuvre du DHCP snooping*  
*mise en œuvre du IP Source Guard*  
*mise en œuvre du Dynamic ARP Inspection*  
*gestion des @IP de hôtes fixes ...*

### TP2 ?

*présentation du contexte des attaques*  
*mise en œuvre d'une attaque par VLAN*  
*mise en œuvre d'une attaque par SPAN/RSPAN*  
*désactivation des protocoles Adhoc*  
*mise en œuvre du Private VLAN*  
*mise en œuvre du port-security*  
*gestion de la sécurité sur de multiples switch*

### TP5 ?

*présentation du contexte des attaques*  
*installation des outils d'attaque (kali)*  
*installation des outils de décryptage*  
*prise en compte de l'infrastructure WiFi*  
*fabrication de machines VM d'attaque*  
*mise en évidence des attaques*  
*production des environnements d'attaque*

mixage de ces propositions ...

Mise en œuvre :

- Packet Tracer limité
- GSN3 limité ...
- matériels incontournables

Outils :

- VMWare Workstation player
- GSN3
- IOS Cisco pour GNS3
- WinRadius
- Kali linux pour VMWare

### TP3 ?

*présentation du contexte des attaques*  
*mise en œuvre de RACL*  
*mise en œuvre de VACL*  
*mise en œuvre de PACL*  
*mise en œuvre de restrictions sur les accès*  
*définition d'une politique d'utilisation des ACL*  
*évaluation de la robustesse de la politique*

### TP4 ?

*présentation du contexte des attaques*  
*mise en œuvre d'une authentification TACAC+*  
*mise en œuvre d'une authentification RADIUS*  
*traçage des logs*  
*mise en œuvre du protocole 802.1x*  
*définition d'une politique des identifiants/mdp*  
*évaluation de la robustesse de la politique*

6h de TP en salle 409 + perso : **date limite 16 avril**